

PROYECTO FINAL DE CURSO – SEGURIDAD DE LA INFORMACIÓN

MODELO DEL SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (SGSI) DE LA ASOCIACIÓN MUNICIPAL DE PELOTA FRONTON SUCRE (AMPFS)



INTEGRANTES

Mendez Condori Alex Ramiro
Loayza Cruz Axel Gianfranco
Polo Orellana Brayan Slmón
Vela Gutiérrez Elmer Kevin
Rodas Palacios Max Jhsrson
Leaños Ortiz Adan
Manjon Blanco Susana
Vargas Oropeza Isaac Joseph

**UNIVERSIDAD MAYOR REAL Y PONTIFICIA SAN FRANCISCO
XAVIER DE CHUQUISACA**



**FACULTAD DE TECNOLOGÍA
SIS 254 – SEGURIDAD DE LA INFORMACIÓN
SUCRE BOLIVIA**



INDICE

- I. MARCO INTRODUCTORIO**
 - i. INTRODUCCIÓN**
 - ii. OBJETIVOS**
 - Objetivo general
 - Objetivos específicos
 - iii. JUSTIFICACIÓN**
 - iv. ALCANCE Y LIMITACIONES**
 - Alcance
 - Limitaciones
 - v. GLOSARIO DE TERMINOS Y DEFINICIONES**
- II. CAPITULO I: MARCO NORMATIVO Y CONTEXTO (ISO 27001)**
 - 1.1. Marco legal vigente**
 - 1.2. Análisis del contexto**
 - 1.2.1. Perfil de la Asociación: Misión, visión y estructura**
 - 1.2.2. Análisis DAFO: Fortalezas y amenazas externas**
 - 1.3. Partes interesadas**
- III. CAPITULO II: LIDERAZGO Y POLITICA**
 - 2.1. Compromiso de la Dirección**
 - 2.2. Política de Seguridad de la información (PSI)**
 - 2.2.1. Marco de Intenciones y Objetivos (Parte A)**
 - 2.2.2. Principios de Protección de Activos (Parte B)**
 - 2.2.3. Directrices de Desarrollo Seguro (Parte C)**
 - 2.2.4. Compromisos de Cumplimiento y Mejora (Parte D)**
 - 2.3. Roles, Responsabilidades y Autoridades**
 - 2.3.1. Alta Dirección (Directiva de la Asociación)**
 - 2.3.2. Comité del SGSI (Órgano de Gobernanza)**
 - 2.3.3. Responsable del SGSI / CISO**
 - 2.3.4. Equipo de Desarrollo Seguro**
 - 2.3.5. Equipo de Seguridad y Cumplimiento**
 - 2.3.6. Propietarios de Activos y Usuarios**
- IV. CAPITULO III: PLANIFICACIÓN Y GESTIÓN DE RIESGOS (ISO 27005)**
 - 3.1. Metodología de Evaluación de Riesgos**
 - 3.1.1. Fases del proceso**
 - 3.1.2. Escala de Valoración y Cálculo**
 - 3.1.3. Matriz de Aceptabilidad (Mapa de Calor)**
 - 3.2. Inventario y Clasificación de Activos**
 - 3.2.1. Identificación y Clasificación de Activos**
 - 3.2.2. Matriz de Inventario y Valoración de Activos**

- 3.3. Matriz de Riesgos
 - 3.3.1. Análisis y Discusión de los Resultados del Diagnóstico de Riesgos
 - 3.4. Plan de Tratamientos de Riesgos y SoA
 - 3.4.1. Justificación de Exclusiones y Viabilidad del Tratamiento
- V. CAPITULO IV: OPERACIÓN Y SEGURIDAD TÉCNICA (ISO 27034)
 - 4.1. Seguridad en el Desarrollo de Aplicaciones
 - 4.2. Proceso ASMP (Application Security Management Process)
 - 4.3. Definición del Target LoA (Level of Assurance)
 - 4.4. Controles de Seguridad de Aplicación (ASC)
 - 4.5. Seguridad de Red e Infraestructura
- VI. CAPITULO V: SOPORTE, CONTINUIDAD Y MEDICIÓN (ISO 27031 y 27004)
 - 5.1. Concienciación y Comunicación
 - 5.2. Continuidad TIC (DRP)
 - 5.3. Métricas e Indicadores (KPIs)
- VII. CAPITULO VI: EVALUACIÓN Y MEJORA
 - 6.1. Auditoría Interna
 - 6.2. Revisión por la Dirección
 - 6.3. Mejora Continua (Ciclo PHVA)
- VIII. CONCLUSIONES Y RECOMENDACIONES
- IX. BIBLIOGRAFÍA
- X. ANEXOS

I. MARCO INTRODUCTORIO

i. INTRODUCCIÓN

La Asociación Municipal de Pelota Frontón Sucre, con una trayectoria institucional de 62 años, es el pilar de la gestión deportiva de esta disciplina en la ciudad, coordinando aproximadamente 50 clubes y un promedio de 300 jugadores por campeonato. A pesar de su sólida historia, la gestión de la información (fixtures, registros de jugadores, resultados y permisos) se ha realizado tradicionalmente de forma manual y en soporte físico, lo que conlleva una alta inversión de tiempo y procesos complejos de organización.

En la actualidad, la Asociación ha iniciado un proceso de transformación digital mediante el desarrollo de un software a medida en tecnologías Next.js y NestJS. Sin embargo, este salto tecnológico introduce riesgos digitales que antes no existían, como la posibilidad de accesos no autorizados a la base de datos o la filtración de información estratégica antes de los torneos. Por ello, este proyecto propone el diseño de un Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma ISO/IEC 27001, para asegurar que esta transición digital sea segura, íntegra y confiable.

ii. OBJETIVOS

- Objetivo general

Diseñar un modelo de Sistema de Gestión de Seguridad de la Información (SGSI) para la Asociación Municipal de Pelota Frontón Sucre, alineado a la norma ISO/IEC 27001, que garantice la protección de los activos de información y la validación técnica del software de gestión de campeonatos.

- Objetivos específicos

- Diagnosticar el estado actual de la seguridad de la información en la Asociación, identificando las vulnerabilidades de la gestión documental física y los requisitos del nuevo software.
- Realizar una evaluación de riesgos (ISO 27005) sobre los activos críticos, como el registro de jugadores (PII) y los cronogramas de partidos, para mitigar amenazas de alteración o filtración.
- Definir políticas y controles técnicos de desarrollo y conectividad (ISO 27002, ISO 27033 e ISO 27034) para asegurar el tráfico de la red local y garantizar que el código fuente del software incluya validaciones que impidan la manipulación de resultados y fixtures.

- Establecer un Plan de Continuidad TIC (ISO 27031) que proteja la imagen de la Asociación ante posibles caídas del sistema, garantizando la recuperación de la información registrada por los organizadores.

iii. JUSTIFICACIÓN

La implementación de un SGSI en la Asociación se justifica por tres pilares fundamentales:

- **Integridad Deportiva y Transparencia:** Uno de los riesgos críticos identificados es la filtración de fixtures antes de su publicación oficial (conocido localmente como "tejer"). El SGSI establecerá controles de confidencialidad para evitar colusiones y garantizar que solo el organizador y el presidente de árbitros gestionen las programaciones.
- **Protección de Datos Personales (PII):** Al manejar datos sensibles de más de 300 atletas (Nombres, C.I., fechas de nacimiento), la Asociación tiene la responsabilidad legal (Ley 164) y ética de proteger esta información contra filtraciones que podrían dañar la privacidad de sus socios.
- **Eficiencia Operativa:** El paso del papel al software reducirá drásticamente el tiempo de organización de torneos. El SGSI asegura que esta eficiencia no se pierda por incidentes de integridad (alteración de resultados ya jugados) o daños a la imagen institucional ante los clubes afiliados.

iv. ALCANCE Y LIMITACIONES

- **Alcance:** El alcance del Sistema de Gestión de Seguridad de la Información para la Asociación Municipal de Pelota Frontón Sucre comprende:
 - **Procesos:** La gestión integral de campeonatos, el registro y control de atletas, y la programación y resultados de partidos.
 - **Activos Lógicos:** El software de gestión desarrollado en Next.js, NestJS y la base de datos PostgreSQL, la configuración de Red y el segmento de Red Local.
 - **Activos Físicos:** La estación de trabajo (PC de escritorio) del organizador, la infraestructura de red (router administrativo), las oficinas administrativas (espacio físico de gestión), los sistemas de seguridad (cámaras de videovigilancia y alarmas del recinto) y los dispositivos móviles donde se ejecutará la aplicación de software.
 - **Activos Documentales:** Toda la información histórica y actual contenida en soportes físicos, tales como Kardex de

jugadores, planillas de resultados y formularios de traspasos, los cuales sirven de insumo para el nuevo sistema.

- **Alcance de Personal:** Las políticas y controles aplicarán directamente al Organizador de campeonatos (como usuario principal y administrador) y a los Jugadores (como titulares de la información).

- **Limitaciones del proyecto**

- **Económicas:** El proyecto no contempla la inversión de capital para la adquisición de licencias de software de seguridad pagas (ej. Antivirus corporativos), limitándose al uso de herramientas gratuitas o integradas en el sistema operativo.
- **Técnicas:** El proyecto contempla el despliegue del software en un entorno híbrido. La base de datos y la aplicación administrativa se alojarán en un Servidor Virtual Privado (VPS) en la nube para permitir el acceso remoto seguro de los delegados y la automatización de respaldos. Por otro lado, en la sede física de la Asociación (Estadio Patria), el alcance técnico se delimita a la configuración lógica de la red local (LAN) mediante un router administrativo para asegurar la estación de trabajo del organizador, el uso de IPs estáticas para el control de acceso al panel de administración, y la gestión local de un sistema de videovigilancia IP para resguardar los activos físicos y documentales. El uso de software complementario se restringe a soluciones de código abierto (open-source).
- **Temporales:** Aunque el modelo incluye las fases de revisión y mejora continua (PHVA) tras la entrega final y la auditoría externa, la implementación física total de todos los controles sugeridos quedará sujeta a la disponibilidad de recursos de la Asociación.

v. **GLOSARIO DE TERMINOS Y DEFINICIONES**

Nota: Este glosario se basa en la terminología oficial de la ISO/IEC 27000:2018.

- **Activo de Información:** Cualquier cosa que tiene valor para la organización y que se relaciona con la información o sus procesos (ej. datos de jugadores, PC, software).
- **Confidencialidad, Integridad y Disponibilidad (C-I-D):** Propiedades que aseguran que la información no se divulgue a personas no autorizadas, se mantenga exacta y completa, y esté accesible cuando se requiera.

- **Riesgo:** El efecto de la incertidumbre sobre los objetivos de la Asociación, caracterizado por la probabilidad de un evento y su consecuencia.
- **Amenaza:** Causa potencial de un incidente no deseado que puede resultar en daño para un sistema u organización.
- **Vulnerabilidad:** Debilidad de un activo o control que podría ser explotada por una o más amenazas.
- **Control:** Medida que modifica el riesgo, incluyendo cualquier política, procedimiento o configuración técnica.
- **Información Personal Identificable (PII):** Cualquier dato que pueda utilizarse para identificar a una persona física, como los nombres y C.I. de los jugadores.
- **Incidente de Seguridad:** Evento inesperado que tiene una probabilidad significativa de comprometer las operaciones de la Asociación.
- **Declaración de Aplicabilidad (SoA):** Documento que detalla los controles de la ISO 27002 que son aplicables al proyecto, justificando su inclusión o exclusión.
- **Parte Interesada (Stakeholder):** Persona u organización que puede afectar, ser afectada o percibirse afectada por una decisión o actividad del SGSI.

II. CAPITULO I: MARCO NORMATIVO Y CONTEXTO (ISO 27001)

1.1. Marco legal vigente: La Asociación Municipal de Pelota Frontón Sucre, en cumplimiento de sus funciones de gestión deportiva con 62 años de trayectoria, establece que su SGSI se sujeta estrictamente al siguiente marco legal y normativo para garantizar la seguridad de su activo más valioso: la información de sus atletas y clubes. Se adopta como estándar para garantizar que el proveedor de Alojamiento (VPS/Nube) seleccionado trate la Información Personal Identificable (PII) de los 300 jugadores bajo estrictos controles internacionales de privacidad y cifrado.

- **Constitución Política del Estado Plurinacional de Bolivia:** El SGSI reconoce el derecho fundamental de toda persona al deporte y la cultura física (Art. 104), así como el deber de la Asociación de gestionar esta actividad bajo principios de transparencia y especialización deportiva.
- **Ley N° 164 (Ley General de Telecomunicaciones y TIC):** Constituye el pilar jurídico principal del SGSI. La Asociación garantiza la inviolabilidad y secreto de las comunicaciones de sus miembros (Art. 5 y 56) y adopta el principio de validez jurídica y probatoria para todos los actos y documentos digitales, mensajes de datos y firmas que el nuevo software genere (Art. 78 y 86).

- **Código de Comercio de Bolivia:** Dado que la Asociación realiza transacciones por inscripciones (Bs. 100) y otros conceptos, este código obliga al resguardo íntegro de la documentación comercial. El SGSI digitaliza el proceso de recibos de doble vía (uno para la institución y otro para el delegado), asegurando la conservación de los registros financieros y la autenticidad de los estados financieros presentados por la Secretaría de Hacienda.
- **Ley Nacional del Deporte (Ley N° 804):** El SGSI se alinea a esta ley para asegurar que las entidades deportivas manejen su información de interés público con integridad, especialmente en lo referente a la organización de campeonatos selectivos y el registro de deportistas.
- **Estatutos y Reglamentos Internos:** El sistema se rige por el Reglamento Oficial de Juego y el Código de Penas de la Federación. Se protege la confidencialidad de los fallos disciplinarios y la integridad de los cronogramas de partidos (fixtures) para evitar filtraciones previas o alteraciones de resultados una vez registrados por el organizador [Conversación previa, 13].
- **ISO/IEC 27001:2022 (SGSI - Requisitos):** Adoptada como la norma principal que especifica los requisitos para establecer, implementar y mejorar continuamente el SGSI de la Asociación mediante un enfoque basado en riesgos.
- **ISO/IEC 27034 (Seguridad de Aplicaciones):** Utilizada como guía para que el equipo de desarrollo (Polo, Max, Vela, Mendez) integre controles de seguridad (ASC) en el código del software Next.js/NestJS, garantizando la resistencia contra ataques como inyecciones SQL desde su diseño.
- **ISO/IEC 27018 (Privacidad en la Nube):** Referencia normativa seleccionada para garantizar que, en caso de alojar el sistema en un VPS o servidor en la nube, se cumplan los controles internacionales de protección de datos personales identificables (PII) de los 150 jugadores registrados.

1.2. Análisis del contexto: De acuerdo con la cláusula 4.1 de la norma, la Asociación debe comprender las cuestiones internas y externas que afectan su capacidad para proteger la información.

1.2.1. Perfil de la Asociación: Misión, visión y estructura: La Asociación es una institución con 62 años de trayectoria, cuya única sede administrativa se encuentra en la Calle Rene Calvo Arana, puerta número 18 del Estadio Patria (Frontones).

- **Misión Institucional:** Fomentar la práctica de la pelota frontón, promoviendo un ambiente inclusivo y seguro para que jugadores

de todas las edades y niveles puedan disfrutar de estos deportes, contribuyendo al desarrollo físico, mental y social de sus miembros.

- **Visión Institucional:** Ser la asociación deportiva líder en la promoción y desarrollo de las diferentes especialidades de la disciplina de pelota frontón a nivel local y nacional, fomentando la participación de la comunidad y el fomento de los valores deportivos.
- **Estructura Organizacional (Alta Dirección):** La responsabilidad del SGSI recae sobre la directiva actual, compuesta por:
 - Presidente
 - Vicepresidente
 - Secretario General
 - Secretario de Actas
 - Secretario de Hacienda
 - Secretario de Estadística
 - Secretario de Infraestructura Deportiva
 - Comisión Técnica Pelota Raqueta
 - Comisión Técnica Pelota de Mano
 - Vocales

1.2.2. Análisis DAFO: Fortalezas y amenazas externas: El diagnóstico de seguridad revela factores críticos basados en la memoria institucional y la operación actual:

Factor	Descripción
Fortaleza (F)	Trayectoria sólida y directiva actual comprometida con la transparencia. Existencia de reglamentos oficiales que rigen la conducta y los partidos.
Debilidad (D)	Brecha de competencia digital: Exceptuando al organizador, la directiva carece de conocimientos técnicos básicos. Falta de evidencia física para auditar incidentes de fuga de datos del pasado.
Oportunidad (O)	Disponibilidad de infraestructura escalable en la nube (VPS) que permite accesos remotos seguros para delegados mediante tokens, pasarelas de autenticación y la implementación de respaldos automáticos, eliminando la fragilidad y dependencia de una única PC de escritorio local.

Amenaza (A)	Riesgo de ciberataques (Inyección SQL, XSS) al nuevo sistema si no se aplican los controles técnicos mandatorios definidos en la Política de Seguridad.
--------------------	---

1.3. Partes interesadas: Siguiendo la cláusula 4.2, se definen los requisitos de seguridad para los actores que interactúan con el sistema de campeonatos:

Parte interesada	Requisito de Seguridad de la información	Impacto en el SGSI
Presidente	Garantizar la legalidad de la gestión ante la Ley 164 y proteger la imagen institucional.	Gobernanza y Liderazgo.
Delegados y Clubes	Garantía de que los partidos procedan de manera justa, sin trampas ni alteraciones en los cronogramas.	Integridad de los datos.
Comisión Técnica	Integridad absoluta en el procesamiento de fallos y fixtures para evitar colusiones.	Control de Operaciones.
Jugadores	Privacidad en el tratamiento de sus datos personales (C.I., fotos) y vinculación legal de sus firmas en las planillas físicas como mecanismo de no repudio antes del registro digital.	No repudio, integridad de la información y Privacidad (ISO 27018).
Árbitros	Resguardo de las planillas de control frente a presiones externas de directivos o jugadores.	Integridad de registros.

III. CAPITULO II: LIDERAZGO Y POLITICA

2.1. Compromiso de la Dirección: De acuerdo con la norma ISO/IEC 27001, la Alta Dirección de la Asociación Municipal de Pelota Frontón Sucre, encabezada por su presidente, y su directiva, demuestra su liderazgo y compromiso incondicional con el Sistema de Gestión de Seguridad de la Información (SGSI) mediante las siguientes acciones estratégicas:

- **Aprobación y Apoyo Estratégico:** Asegurando que la Política de Seguridad y los objetivos del SGSI sean compatibles con la misión institucional de fomentar el deporte de manera inclusiva y segura.
- **Integración de Procesos:** Garantizando que los requisitos de seguridad (como la validación de firmas en planillas y la confidencialidad de los fixtures) se integren plenamente en el proceso de gestión de campeonatos y registro de atletas.
- **Asignación de Recursos:** Comprometiéndose a proporcionar el tiempo de planificación y los recursos humanos necesarios (equipos de documentación, desarrollo y seguridad) para la implementación y mantenimiento eficaz del sistema.
- **Comunicación de la Importancia:** Promoviendo una cultura de seguridad dentro de la Asociación, enfatizando ante los 50 clubes afiliados y los 300 jugadores la importancia de cumplir con la Ley 164 y proteger la integridad de los resultados deportivos.
- **Enfoque en la Mejora Continua:** Liderando las revisiones periódicas del desempeño del sistema para asegurar que el software y los controles físicos evolucionen ante nuevas amenazas digitales.

Declaración de Compromiso

"Como presidente de la Asociación Municipal de Pelota Frontón Sucre, reconozco que la información de nuestros atletas y la transparencia de nuestros torneos son activos estratégicos fundamentales. Por ello, asumo la responsabilidad máxima de dirigir y apoyar la implementación de este SGSI, asegurando que cada miembro de la directiva y cada usuario del sistema comprenda y cumpla con sus deberes de seguridad para proteger nuestra trayectoria institucional de 62 años."

Firma:

Presidente

2.2. Política de Seguridad de la información (PSI): La presente Política de Seguridad de la Información es el documento de máxima jerarquía normativa dentro del SGSI de la Asociación Municipal de Pelota Frontón Sucre. Define las intenciones y la dirección de la directiva para proteger sus activos contra amenazas internas y externas.

2.2.1. Marco de Intenciones y Objetivos (Parte A): La Asociación se compromete a proteger la trayectoria institucional de 62 años mediante un entorno digital seguro. El SGSI adopta el

principio de Seguridad por Diseño, integrando controles técnicos desde el código fuente desarrollado en NestJS y Next.js para garantizar la transparencia competitiva y la confianza institucional.

A. Misión de Seguridad La misión del SGSI es establecer un entorno digital y físico seguro que permita el desarrollo de campeonatos íntegros, eliminando prácticas no éticas como la filtración estratégica de cronogramas ("tejer") y garantizando que cada resultado deportivo sea veraz y auditable.

B. Objetivos Estratégicos de la Política Para cumplir con su propósito, la Asociación establece los siguientes lineamientos de alto nivel:

a) **Protección de la Triada C-I-D:** Garantizar la Confidencialidad de los datos personales de los jugadores, la Integridad de los fixtures y resultados, y la Disponibilidad del software de gestión para el organizador y delegados.

b) **Seguridad por Diseño:** Adoptar la seguridad como un elemento estructural y no accesorio, integrando controles técnicos desde el código fuente del software desarrollado en NestJS y Next.js para prevenir ciberataques que comprometan la imagen de la Asociación.

c) **Cumplimiento Legal y Normativo:** Asegurar el cumplimiento estricto de la Ley N° 164 de Bolivia, otorgando validez jurídica a los documentos y firmas digitales generadas por el sistema, y protegiendo los registros financieros de la Secretaría de Hacienda.

d) **Marco para Objetivos de Seguridad:** Esta política proporciona el marco de referencia para establecer indicadores de desempeño (KPIs) que permitan medir la reducción de incidentes de seguridad y el éxito de la transformación digital de la institución.

C. Compromiso de Mejora Continua La directiva se compromete a proporcionar los recursos necesarios para que el SGSI evolucione mediante el ciclo PHVA (Planificar-Hacer-Verificar-Actuar), asegurando que los controles se actualicen ante nuevas amenazas tecnológicas y cambios en la estructura de la Asociación.

2.2.2. Principios de Protección de Activos (Parte B): La Asociación fundamenta la protección de sus activos de información en la tríada Confidencialidad, Integridad y

Disponibilidad (C-I-D), aplicando estos principios tanto a los soportes físicos como a las herramientas digitales.

A. Confidencialidad: El acceso al software administrativo requiere autenticación robusta mediante tokens JWT (JSON Web Tokens) firmados y autenticación federada con Google OAuth 2.0.

a) Protección de Datos Personales (PII): Los nombres, C.I., números de teléfono y registros de salud contenidos en los Kardex físicos y digitales se clasifican como información restringida. Su acceso está limitado exclusivamente al Organizador y al Secretario General para fines de habilitación deportiva.

b) Control de Acceso Basado en Roles (RBAC): El software implementará el principio de "mínimo privilegio", definiendo perfiles de usuario (Admin, Organizador, Delegado, Jugador) con permisos estrictamente necesarios para su función, evitando que personas ajenas consulten información sensible.

c) Seguridad en el Acceso: El acceso al sistema administrativo desde la PC de la oficina o dispositivos remotos requerirá autenticación robusta mediante tokens JWT y, opcionalmente, OAuth 2.0, para asegurar que la sesión no sea interceptada.

B. Integridad: Se prohíben las consultas SQL directas. Toda interacción con la base de datos PostgreSQL debe realizarse mediante el ORM (TypeORM) usando consultas parametrizadas para mitigar el riesgo de inyección de datos.

a) Validación de Resultados y Mecanismo de No Repudio: Para evitar la alteración maliciosa de marcadores, la validez del resultado digital introducido en el software dependerá obligatoriamente de la planilla física de control de partidos, firmada por los jugadores y el árbitro al finalizar el encuentro. El Organizador será el único autorizado para transcribir estos datos al sistema. Una vez guardados, el software Next.js/NestJS emitirá un reporte digital inmutable con un código de verificación único que deberá coincidir con la planilla física custodiada, sirviendo esta última como el respaldo final de auditoría ante cualquier reclamo o sospecha de alteración de datos.

b) Protección contra el "Teje": Se prohíbe la modificación manual de los cronogramas (fixtures) una vez publicados oficialmente, a menos que exista una

resolución justificada de la Comisión Técnica que sea registrada en el log de auditoría del sistema.

- c) **Seguridad de la Base de Datos:** Se utilizarán roles específicos en PostgreSQL (app_readwrite, app_readonly) para asegurar que el software NestJS solo realice las operaciones permitidas sobre los datos de las categorías y equipos, protegiendo la estructura de la base de datos contra inyecciones de código.

C. **Disponibilidad:** La Asociación garantiza la operatividad del sistema mediante la gestión de niveles de servicio (SLA) con el proveedor de VPS, asegurando la continuidad de los torneos.

- a) **Operatividad del Software:** La Asociación garantizará que el sistema de gestión esté disponible para los delegados y jugadores durante toda la vigencia del campeonato, gestionando niveles de servicio (SLA) con el proveedor de Alojamiento (Hosting/VPS).
- b) **Resguardo de Activos Físicos:** La PC de escritorio del organizador y el router administrativo deben contar con protecciones físicas y suministros de energía redundantes (UPS) para evitar que fallas técnicas o cortes eléctricos detengan la programación de partidos en la sede del Estadio Patria.
- c) **Custodia Documental:** Los formularios de traspasos y registros históricos en papel serán custodiados en archivadores protegidos en la oficina administrativa (Puerta 18), garantizando su recuperación en caso de fallo de los sistemas digitales.

2.2.3. Directrices de Desarrollo Seguro (Parte C)

- **Validación de Datos:** Uso de class-validator y class-transformer en el backend para sanear entradas.
- **Seguridad HTTP:** Implementación obligatoria del middleware Helmet para configurar cabeceras de seguridad contra ataques de Clickjacking y XSS.
- **Verificación Continua:** Ejecución periódica de análisis de dependencias con npm audit y herramientas de análisis estático (SAST).

A. Estándares de Codificación Segura (ISO 27034)

- a) **Adopción Normativa:** El equipo de desarrollo debe seguir las directrices de la norma ISO/IEC 27034 para integrar la seguridad en el ciclo de vida de la aplicación,

priorizando la protección contra las amenazas del OWASP Top 10.

- b) **Validación de Entradas:** Es obligatorio el uso de los paquetes class-validator y class-transformer en el backend NestJS para sanear y rechazar cualquier dato malformado antes de ser procesado por el sistema.
- c) **Prevención de Inyección SQL:** Se prohíbe el uso de consultas SQL directas (raw queries); toda interacción con la base de datos debe realizarse a través de TypeORM, garantizando el uso exclusivo de consultas parametrizadas.

B. Autenticación y Control de Acceso Lógico

- a) **Gestión de Identidad:** El acceso de usuarios (organizadores y delegados) debe estar protegido mediante tokens JWT (JSON Web Tokens) firmados y, de forma preferente, autenticación federada con Google OAuth 2.0.
- b) **Autorización granular:** Se deben implementar Guards de NestJS para evaluar los roles (Admin, User) en cada solicitud, asegurando que ningún usuario acceda a funciones fuera de su competencia.

C. Protección de la Capa de Presentación

- a) **Mitigación de XSS:** Se debe aprovechar el escape automático de React/Next.js para prevenir ataques de inyección de scripts, prohibiendo estrictamente el uso de funciones que omitan este control, como dangerouslySetInnerHTML.
- b) **Gestión de Secretos:** Las credenciales de base de datos y llaves de API deben manejarse exclusivamente en el entorno del servidor, prohibiendo el uso del prefijo NEXT_PUBLIC_ para datos sensibles que puedan filtrarse al navegador del usuario.

D. Verificación Técnica y Mejora Continua

- a) **Análisis de Seguridad:** Es obligatorio realizar análisis estáticos de código (SAST) mediante herramientas como SonarQube o Snyk y ejecutar escaneos de dependencias (SCA) con npm audit para identificar vulnerabilidades antes de cada despliegue.
- b) **Cabeceras de Seguridad:** El software debe implementar el middleware Helmet para configurar cabeceras HTTP de seguridad (CSP, HSTS, X-Frame-Options), protegiendo a la Asociación contra ataques de clickjacking y sniffing.

2.2.4. Compromisos de Cumplimiento y Mejora (Parte D): La Asociación, a través de su Alta Dirección, establece los mecanismos de control para garantizar que los principios de seguridad definidos anteriormente se mantengan vigentes, sean legales y mejoren con el tiempo.

A. Cumplimiento Legal y Contractual

- a) **Acatamiento Normativo:** El SGSI se compromete al cumplimiento estricto de la Ley N° 164 (Ley General de Telecomunicaciones y TIC), garantizando la inviolabilidad de las comunicaciones y la validez jurídica de las firmas y documentos digitales generados por el software en cumplimiento de los estándares de certificación vigente.
- b) **Transparencia Administrativa:** Se garantiza el resguardo de los registros financieros manejados por la Secretaría de Hacienda conforme al Código de Comercio, asegurando que la digitalización de los recibos de inscripción no comprometa su valor probatorio ante auditorías externas.
- c) **Protección de la Privacidad:** El tratamiento de los datos personales de los 150 atletas se realizará bajo los lineamientos de la ISO/IEC 27018, informando a los interesados de forma transparente sobre el uso de su información mediante políticas de privacidad integradas en el sistema.

B. Monitoreo y Revisión por la Dirección

- a) **Auditorías Internas:** La Asociación se compromete a realizar revisiones periódicas del SGSI para determinar si los controles técnicos y operativos se encuentran conformes a los requisitos de la norma ISO 27001 y a los objetivos marcados por la directiva.
- b) **Evaluación del Desempeño:** El Presidente y su directiva revisarán anualmente el desempeño del sistema, prestando especial atención a la efectividad del software frente a intentos de alteración de resultados y al cumplimiento de la integridad de los fixtures.

C. Mejora Continua y Gestión de No Conformidades

- a) **Ciclo PDCA:** La Asociación adopta la metodología de mejora continua Planificar-Hacer-Verificar-Actuar (PDCA), asegurando que ante cualquier fallo de

seguridad detectado se realicen análisis de causa raíz para eliminar la probabilidad de reincidencia.

- b) **Tratamiento de Incidentes:** Cualquier filtración de información estratégica ("teje") o debilidad técnica detectada se considerará una "No Conformidad" y activará un proceso de acción correctiva inmediata para proteger la imagen institucional.

D. Concienciación y Cultura Organizacional

- a) **Capacitación:** Reconociendo la brecha digital identificada en el contexto, la directiva se compromete a proporcionar los recursos para programas de formación en seguridad de la información para todo el personal administrativo y delegados de clubes.

2.3. Roles, Responsabilidades y Autoridades: De acuerdo con la cláusula 5.3 de la norma ISO/IEC 27001:2022, la Asociación Municipal de Pelota Frontón Sucre define la siguiente estructura de responsabilidades para asegurar que el SGSI sea efectivo y los requisitos de seguridad se cumplan en todos los niveles.

2.3.1. Alta Dirección (Directiva de la Asociación): Representada por el Presidente y su directiva.

- **Responsabilidad:** Establecer la visión estratégica de seguridad, aprobar la Política de Seguridad (PSI) y asegurar la disponibilidad de recursos (financieros y humanos) para el SGSI.
- **Autoridad:** Aprobación final de planes de tratamiento de riesgos y presupuestos de inversión tecnológica.

2.3.2. Comité del SGSI (Órgano de Gobernanza) Integrado por el Presidente, el Secretario General, la Secretaria de Hacienda y el Responsable del SGSI.

- **Responsabilidad:** Evaluar trimestralmente el desempeño del sistema, revisar incidentes de seguridad (como filtraciones de fixtures) y coordinar la implementación entre áreas.

2.3.3. Responsable del SGSI / CISO

- **Responsabilidad:** Liderar el diseño, implementación y operación diaria del SGSI. Coordinar a los equipos técnicos y de documentación, y reportar el estado de los riesgos a la Alta Dirección.
- **Autoridad:** Emitir procedimientos de seguridad obligatorios y coordinar la respuesta ante incidentes detectados en el software o archivos físicos.

2.3.4. Equipo de Desarrollo Seguro

- **Responsabilidad:** Integrar controles de seguridad técnicos (ASC) en el ciclo de vida del software basado en la ISO/IEC 27034.

Implementar validaciones de firmas e integridad de datos en el backend de NestJS.

- **Autoridad:** Determinar los métodos técnicos de cifrado, sanidad de datos y mecanismos de autenticación (JWT/OAuth) para proteger la base de datos PostgreSQL y la información de los 300 jugadores.

2.3.5. Equipo de Seguridad y Cumplimiento

- **Responsabilidad:** Realizar el análisis de riesgos (ISO 27005), elaborar el inventario de activos y redactar el informe técnico de alojamiento (Hosting) bajo controles de la ISO 27002.
- **Autoridad:** Verificar que los proveedores externos (VPS) cumplan con los niveles de privacidad exigidos por la ISO/IEC 27018.

2.3.6. Propietarios de Activos y Usuarios

- **Responsabilidad (Organizador):** Custodiar la integridad de los cronogramas deportivos y asegurar que el registro de resultados sea veraz.
- **Responsabilidad (Hacienda):** Garantizar la integridad y disponibilidad de los registros financieros y recibos de inscripción de los clubes.
- **Responsabilidad General:** Cumplir con las políticas de uso aceptable y reportar cualquier evento de seguridad sospechoso de inmediato.

IV. CAPITULO III: PLANIFICACIÓN Y GESTIÓN DE RIESGOS (ISO 27005)

3.1. Metodología de Evaluación de Riesgos: La Asociación adopta un enfoque de gestión de riesgos basado en la norma ISO/IEC 27005, asegurando que las decisiones de seguridad se fundamenten en un análisis objetivo y sistemático de los activos de información.

3.1.1. Fases del proceso: El proceso se divide en tres etapas fundamentales conforme a la cláusula 6.1.2 de la ISO 27001.

- **Identificación del Riesgo:** Reconocer qué amenazas podrían explotar vulnerabilidades en los activos (software, base de datos, Kardex físicos) y cuáles serían sus consecuencias (ej. alteración de resultados).
- **Análisis del Riesgo:** Comprender la naturaleza del riesgo determinando su nivel mediante la combinación de su impacto y su probabilidad.
- **Evaluación del Riesgo:** Comparar el nivel de riesgo hallado con los criterios de aceptación de la Asociación para priorizar su tratamiento.

3.1.2. Escala de Valoración y Cálculo: Para cuantificar el riesgo, se utiliza la fórmula fundamental: Nivel de Riesgo (R) = Impacto (I) × Probabilidad (P).

- **Impacto (I):** Se mide del 1 al 5 según el daño a la tríada Confidencialidad, Integridad y Disponibilidad (C-I-D) y el cumplimiento de la Ley 164.
 - **Bajo (1-2):** Afectación mínima que no detiene los torneos ni expone datos sensibles.
 - **Medio (3):** Interrupción temporal del software o filtración de datos de uso interno.
 - **Alto/Crítico (4-5):** Alteración de resultados oficiales, pérdida de registros financieros de Hacienda o fuga masiva de C.I. de los 150 jugadores.
- **Probabilidad (P):** Se mide del 1 al 5 según la frecuencia esperada del evento.
 - **Rara (1):** Menos de una vez cada 10 años.
 - **Posible (3):** Ha ocurrido en directivas anteriores (como el "tejer" de fixtures).
 - **Casi Segura (5):** Ocurrirá en la mayoría de las circunstancias si no hay controles técnicos.

3.1.3. Matriz de Aceptabilidad (Mapa de Calor): El resultado del cálculo (1 al 25) clasifica el riesgo en:

- **Riesgo Bajo (1-6):** Aceptable. Solo requiere monitoreo.
- **Riesgo Medio (8-12):** Tolerable. Requiere planificación de controles a mediano plazo.
- **Riesgo Alto/Crítico (15-25):** Inaceptable. Requiere tratamiento inmediato mediante controles técnicos en el software o seguridad en el VPS.

3.2. Inventario y Clasificación de Activos: De acuerdo con el requisito de la norma ISO/IEC 27002 (Control 5.9), la Asociación identifica y documenta sus activos para preservar su seguridad y asignar responsabilidades claras de custodia.

3.2.1. Identificación y Clasificación de Activos: Los activos se agrupan en categorías para facilitar su gestión y análisis de riesgos posterior.

- **Software (SW):** Aplicaciones desarrolladas y herramientas de soporte.
- **Datos/Información (DT):** Registros digitales y físicos esenciales para los torneos.
- **Hardware (HW):** Equipos físicos e infraestructura de red.
- **Servicios (S):** Servicios externos de conectividad y alojamiento.

3.2.2. Matriz de Inventario y Valoración de Activos: Se utiliza una escala de valoración del 1 al 5 para medir el impacto en caso

de pérdida de Confidencialidad (C), Integridad (I) o Disponibilidad (D).

ID	Activo de información	Tipo	Ubicación	C	I	D
A01	Software de Gestión Deportiva	SW	Servidor VPS	4	5	5
A02	Base de Datos	DT	Servidor VPS	5	5	4
A03	Kardex Físicos	DT	Oficina	3	5	4
A04	Planillas de Control de Partidos	DT	Oficina	2	5	4
A05	Servidor Virtual Privado	S	Nube	4	4	5
A06	PC de Escritorio Administrativa	HW	Oficina	3	4	4
A07	Router y Conectividad de Red	HW	Oficina	2	3	5
A08	Registros Financieros e Inscripciones	DT	Oficina	4	5	4

3.3. Matriz de Riesgos: Una vez identificados los activos de información esenciales para la Asociación Municipal de Pelota Frontón Sucre y definidas las múltiples amenazas que los acechan, se procedió a la ejecución de la fase de análisis y evaluación cuantitativa de riesgos. Utilizando la metodología fundamentada en la norma ISO/IEC 27005 y la fórmula de cálculo establecida en la sección anterior.

$$R = \text{Probabilidad} \times \text{Impacto}$$

Se mapearon un total de 16 escenarios específicos de riesgo. Esta evaluación permite medir el nivel de exposición de los sistemas lógicos (Next.js, NestJS, PostgreSQL), la infraestructura física de la sede en el Estadio Patria, y los activos documentales (Kardex y planillas de juego) ante eventos accidentales, ambientales o humanos de carácter malicioso. Los resultados obtenidos se presentan en la siguiente matriz, la cual sirve de línea base para priorizar el Plan de Tratamiento de Riesgos institucional:

ID Riesgo	ID Activo	Activo de la Información	Amenaza Identificada	Vulnerabilidad Explotable	P (1-5)	I (1-5)	Nivel Riesgo (R)	Clasificación
R01	A01	Software de Gestión	Modificación intencionada de fixtures	Falta de registro de auditoría	4	4	16	Critico

				(logs) inmutable en el backend.				
R02	A01	Software de Gestión	Ataques Web automatizados	Ausencia de políticas de contraseñas complejas y falta de MFA	3	3	9	Medio
R03	A02	Base de Datos	Inyección de código malicioso	Uso de consultas SQL crudas (raw queries) sin sanitizar por ORM	3	5	15	Critico
R04	A02	Base de Datos	Pérdida de integridad por concurrencia en inscripciones	Falta de validación estricta de esquemas (class-validator) en NestJS.	3	3	9	Medio
R05	A03	Kardex Físicos	Destrucción o deterioro por siniestro	Almacenamiento en archivadores comunes sin respaldo digitalizado	2	4	8	Medio
R06	A03	Kardex Físicos	Hurto o fuga de datos personales (PII) de atletas	Oficina sin control de llaves y archivadores abiertos en campeonatos.	3	4	12	Medio
R07	A04	Planillas de Partido	Oficina Extravío, daño físico o rotura del documento en cancha	Inexistencia de un procedimiento de custodia y digitalización inmediata.	4	4	16	Critico
R08	A04	Planillas de Partido	Falsificación de marcadores o firmas post-partido	Ausencia de correlatividad numérica foliada y membretada en el papel.	3	5	15	Critico
R09	A05	Servidor VPS	Secuestro de datos por ciberataque global	Sistema operativo desactualizado y puerto SSH por defecto abierto.	2	5	10	Medio

R10	A05	Servidor VPS	Pérdida total por fallo técnico o borrado accidental.	Ausencia total de una política de respaldos (<i>backups</i>) externos.	4	5	20	Critico
R11	A06	PC Administrativa	Infección por virus o spyware a través de dispositivos USB.	Ausencia de software antivirus licenciado debido a presupuesto.	4	3	12	Medio
R12	A06	PC Administrativa	Acceso no autorizado por abandono del puesto del trabajo	Inexistencia de bloqueo automático de pantalla por inactividad.	4	3	12	Medio
R13	A07	Router y red LAN	Interceptación de credenciales de red	Red Wi-Fi no segmentada; compartida entre público y administración	3	4	12	Medio
R14	A07	Router y red LAN	Caida del servicio de internet durante registros en vivo	Dependencia de un único ISP doméstico sin enlace alternativo de contingencia.	4	3	12	Medio
R15	A08	Registros financieros	Alteración o desvío de fondos de inscripciones	Control de caja manual en Excel local sin bitácora de modificaciones.	3	5	15	Crítico
R16	A08	Registros financieros	Descuadre de cuentas por omisiones de registro nocturno.	Falta de conciliación bancaria y ausencia de módulo web financiero.	3	3	9	Medio

3.3.1. Análisis y Discusión de los Resultados del Diagnóstico de

Riesgos: A partir de la matriz de evaluación expuesta, se realizó una distribución y categorización de los 16 riesgos analizados según su nivel de criticidad, obteniendo las siguientes métricas clave para la gobernanza del SGSI:

- **Riesgos Críticos (Nivel 15-25):** Se identificaron 6 riesgos en estado inaceptable (rojo). Estos concentran las amenazas más

severas contra la integridad deportiva y la continuidad operativa, destacando la manipulación de fixtures (R01), las inyecciones SQL a la base de datos (R03), el extravío o falsificación de las planillas de juego en la cancha (R07 y R08), el fraude financiero por cobro de inscripciones (R15) y, de manera crítica, la pérdida absoluta de datos del Servidor VPS debido a la ausencia de políticas de copias de seguridad externas (R10). Estos 6 puntos requieren la aplicación inmediata de controles mandatorios.

- **Riesgos Medios (Nivel 8-12):** Se determinaron 10 riesgos en estado tolerable (amarillo). Si bien no paralizan de forma inmediata las actividades de los 50 clubes o la gestión de la directiva, representan debilidades latentes asociadas a la brecha digital, como la falta de antivirus en la PC local por limitaciones económicas (R11), la ausencia de un bloqueo de pantalla por inactividad (R12), y la falta de segmentación en el router de la red local (R13).
- **Riesgos Bajos (Nivel 1-6):** No se registraron riesgos en esta categoría bajo el estado de control actual, lo que demuestra la alta vulnerabilidad en la que se encuentra la Asociación antes de la implementación de este modelo de SGSI.

La concentración del 37.5% de los riesgos en la escala Crítica confirma que el proceso de transformación digital hacia las tecnologías NestJS y Next.js debe ser respaldado obligatoriamente por controles lógicos y organizacionales desde su diseño. La pérdida de integridad en los resultados o la indisponibilidad de la plataforma no solo dañarían la trayectoria institucional de 62 años de la Asociación, sino que vulnerarían normativas vigentes en el país como la Ley N° 164. Por consiguiente, estos hallazgos justifican y dan paso directo al diseño de la Declaración de Aplicabilidad (SoA) y el Plan de Tratamiento.

- 3.4. Plan de Tratamientos de Riesgos y SoA:** El Plan de Tratamiento de Riesgos define las acciones, tecnologías y responsabilidades necesarias para responder de manera efectiva a los 6 riesgos críticos identificados en el diagnóstico anterior. Para la Asociación Municipal de Pelota Frontón Sucre, la estrategia principal adoptada es la Mitigación del Riesgo mediante controles de ingeniería de software y seguridad física.

En cumplimiento con la norma ISO/IEC 27001:2022, se presenta a continuación la Declaración de Aplicabilidad (SoA), justificando la selección de los controles específicos del Anexo A (Controles Organizacionales, Físicos y Tecnológicos) diseñados para proteger la

integridad deportiva de los 300 atletas y asegurar la infraestructura del ecosistema tecnológico (Next.js, NestJS y PostgreSQL):

ID Riesgo	Riesgo Crítico Identificado	Estrategia	Control ISO 27002:2022 Aplicado	Acción Técnica y Operativa Específica (Tratamiento)	Responsable
R01	Modificación intencionada de fixtures ("El Teje").	Mitigar	A.8.12 Gestión de privilegios de acceso. A.8.15 Registro de operaciones (<i>Logging</i>).	Implementación de Control de Acceso Basado en Roles (RBAC) en NestJS. Desarrollo de una bitácora de auditoría (<i>Audit Log</i>) inmutable en PostgreSQL que registre la ID del usuario, IP, fecha y el cambio exacto de cada resultado.	Equipo de Desarrollo / Administrador
R03	Inyección de código malicioso (SQL Injection) en la BD.	Mitigar	A.8.25 Desarrollo web seguro. A.8.28 Codificación segura.	Prohibición absoluta del uso de consultas SQL crudas (<i>raw queries</i>). Uso obligatorio del mapeador objeto-relacional TypeORM y parametrización automática de variables para neutralizar inyecciones a nivel de persistencia.	Equipo de Desarrollo
R07	Extravío, daño físico o rotura de	Mitigar	A.7.10 Almacenamiento	Implementación de un flujo operativo	Organizador del Torneo

	planillas de control en cancha.		o de información. A.5.37 Gestión de la continuidad.	mandatorio: digitalización (fotografía/escáner) inmediata de la planilla física al finalizar el partido y almacenamiento indexado en el servidor antes de liberar la cancha.	
R08	Falsificación de marcadores o firmas post-partido.	Mitigar	A.5.14 Transferencia de información. A.8.20 Seguridad en el ciclo de vida.	Emisión automática de reportes con códigos de verificación unívocos generados por el backend en NestJS tras el guardado de datos. Impresión de planillas de juego foliadas, seriadas y membretadas imposibles de duplicar de forma casera.	Directiva / Organizador
R10	Pérdida total del VPS por fallo técnico o borrado accidental.	Mitigar	A.8.13 Copias de seguridad (<i>Backups</i>).	Configuración de scripts automatizados de respaldo diario (Cron Jobs) de la base de datos PostgreSQL. Transferencia cifrada de los dumps hacia un almacenamiento o en la nube aislado y	Administrador del Sistema

				externo al VPS principal, garantizando una retención de 30 días.	
R15	Alteración o desvío de fondos de inscripciones (Bs. 100).	Mitigar	A.5.15 Control de acceso. A.8.27 Validación de de entradas de datos.	Desarrollo e integración del módulo financiero dentro del sistema web, obligando al registro del número de depósito bancario y validación mediante <i>class-validator</i> para evitar registros duplicados o manuales externos.	Tesorero / Desarrolladores

3.4.1. Justificación de Exclusiones y Viabilidad del Tratamiento:

La Declaración de Aplicabilidad (SoA) para este SGSI excluye de manera justificada los controles relacionados con el desarrollo de software de terceros y la gestión de centros de datos propios (como el control A.8.14 sobre seguridad de sistemas de soporte), debido a que la Asociación Municipal de Pelota Frontón Sucre terceriza su infraestructura mediante un modelo de Servidor Virtual Privado (VPS) en la nube y desarrolla su código de forma nativa.

La ejecución de este Plan de Tratamiento garantiza que los riesgos con un nivel de exposición inicial Crítico (valores de 15 a 20 en la matriz) sean mitigados y reducidos a un Riesgo Residual Tolerable (valores bajo 6). Tecnologías modernas como los esquemas de validación en Next.js, las restricciones de TypeORM en NestJS, y las copias de seguridad externas automatizadas, se convierten en las salvaguardas que transforman la gestión empírica de la Asociación en un ecosistema deportivo institucionalmente blindado, alineado por completo con el estándar global ISO/IEC 27001.

V. **CAPITULO IV: OPERACIÓN Y SEGURIDAD TÉCNICA (ISO 27034)**

4.1. Seguridad en el Desarrollo de Aplicaciones: El presente apartado documenta la implementación práctica de los controles de seguridad integrados en el ciclo de vida del software de gestión de campeonatos de la Asociación Municipal de Pelota Frontón Sucre, en cumplimiento del estándar ISO/IEC 27034 y los lineamientos de la Parte C de la Política de Seguridad de la Información (PSI) definida en el Capítulo II. El sistema está compuesto por un frontend desarrollado en Next.js y un backend construido con NestJS, utilizando PostgreSQL como motor de base de datos y TypeORM como capa de persistencia. Ambos repositorios (frontend y backend) se encuentran versionados en GitHub, lo que permite la trazabilidad de cambios en el código fuente y la aplicación de controles de revisión previos a cada despliegue.

4.1.1. Autenticación y Control de Acceso (JWT + Passport): De acuerdo con el control A.8.12 de la ISO 27002:2022 (Gestión de privilegios de acceso) y las directrices de la PSI, el backend implementa un mecanismo de autenticación basado en tokens mediante las siguientes dependencias verificadas en el package.json del proyecto:

- @nestjs/jwt ^11.0.2
- @nestjs/passport ^11.0.5
- passport-jwt ^4.0.1

Mediante esta pila tecnológica, cada solicitud al API es interceptada por Guards de NestJS que validan la firma y vigencia del token JWT antes de permitir el acceso a cualquier recurso protegido. Los tokens son generados en el servidor, firmados con una clave secreta gestionada como variable de entorno (no expuesta al cliente) y contienen los reclamos de rol del usuario (Admin, Organizador, Delegado), implementando así el principio de mínimo privilegio que establece el RBAC del sistema.

El acceso con autenticación federada vía Google OAuth 2.0 se contempla como capa adicional preferente, reduciendo el riesgo R02 (ataques de acceso automatizados por credenciales débiles) identificado en la Matriz de Riesgos.

4.1.2. Validación de Entradas y Prevención de Inyección SQL: En cumplimiento del control A.8.28 (Codificación segura) y la

prohibición explícita del uso de raw queries establecida en la PSI, el equipo de desarrollo aplica las siguientes salvaguardas a nivel de código:

- **class-validator y class-transformer:** Implementados obligatoriamente en todos los DTOs del backend NestJS para sanear y rechazar entradas malformadas antes de que lleguen a la capa de negocio o de persistencia. Esto mitiga directamente el riesgo R04 (pérdida de integridad por concurrencia en inscripciones).
- **TypeORM con consultas parametrizadas:** Toda interacción con la base de datos PostgreSQL se realiza exclusivamente a través del ORM, eliminando la superficie de ataque por inyección SQL que representa el riesgo crítico R03.

4.1.3. Seguridad en el Frontend (Next.js): En la capa de presentación, el equipo aplica los controles de la PSI (Parte C) sobre la protección de la capa de presentación:

- **Mitigación de XSS:** Se aprovecha el escape automático del motor de renderizado de React/Next.js. Queda prohibido estrictamente el uso de dangerouslySetInnerHTML en cualquier componente del frontend.
- **Gestión de secretos:** Las credenciales de base de datos, claves JWT y tokens de API se gestionan exclusivamente como variables de entorno del lado del servidor. Se prohíbe el uso del prefijo NEXT_PUBLIC_ para cualquier dato sensible que pueda filtrarse al navegador del usuario final.

4.1.4. Seguridad en el Despliegue (Docker y Repositorio GitHub): El proyecto cuenta con un archivo Dockerfile en el repositorio del backend (verificado en el directorio raíz del proyecto ampfs-udc-backend), lo que permite una contenedorización reproducible del entorno de ejecución. El uso de Docker garantiza el aislamiento del proceso de la aplicación, la consistencia del entorno entre desarrollo y producción, y reduce el riesgo de configuraciones erróneas al desplegar en el VPS.

Respecto a la infraestructura de alojamiento, el equipo evaluó las siguientes opciones de proveedor VPS, todas compatibles con los controles de privacidad de la ISO/IEC

27018 exigidos para el tratamiento de los datos personales (PII) de los atletas:

Proveedor	Ventaja Principal	Relevancia para el SGSI
OVHcloud	Soberanía de datos y certificación ISO 27018 nativa que cubre explícitamente sus VPS	Recomendado como opción prioritaria por su cobertura normativa directa
DigitalOcean	"Droplets" de despliegue ágil con cumplimiento oficial ISO/IEC 27018 para privacidad de datos	Ideal para despliegues rápidos en fases tempranas del proyecto
Akamai (ex-Linode)	Equilibrio entre simplicidad y robustez empresarial con seguridad perimetral de nivel <i>enterprise</i>	Opción sólida para cuando el tráfico de la plataforma escale
AWS / Microsoft Azure	Arquitecturas complejas con paneles de cumplimiento automatizados (hiperescaladores)	Reservados para un crecimiento institucional a largo plazo

El proveedor seleccionado deberá acreditar formalmente el cumplimiento de la ISO/IEC 27018 como condición contractual previa al despliegue, en línea con las responsabilidades del Equipo de Seguridad y Cumplimiento definidas en el Capítulo II.

4.1.5. Gestión de Dependencias y Análisis Estático (pnpm audit): El proyecto utiliza pnpm como gestor de paquetes, lo que aporta ventajas de seguridad frente a alternativas como npm o yarn: su modelo de almacenamiento con hard links y estructura de node_modules estricta (no plana) impide que dependencias no declaradas explícitamente en el package.json sean accesibles por el código de la aplicación, reduciendo el riesgo de ataques de tipo dependency confusión.

En cumplimiento del control A.8.8 (Gestión de vulnerabilidades técnicas) de la ISO 27002:2022, el equipo está obligado a ejecutar periódicamente:

- **pnpm audit:** Antes de cada despliegue a producción, para identificar y catalogar dependencias con vulnerabilidades conocidas (CVEs). La existencia de dependencias con severidad high o critical sin parche disponible bloquea el merge a la rama principal en el repositorio de GitHub.

- **Análisis estático de código (SAST):** Mediante herramientas como SonarQube o Snyk, integradas como pasos del flujo de revisión de código en GitHub, para detectar patrones de código inseguro antes de que lleguen al entorno de producción del VPS.

4.1.6. Registro de Auditoría (Audit Log) - Control Mandatorio:

Dado que el análisis de riesgos identificó la modificación intencionada de fixtures como el riesgo de mayor prioridad operativa (R01, nivel Crítico = 16) y que actualmente no se dispone de un módulo de auditoría implementado en el backend, este control se establece como un desarrollo pendiente de carácter mandatorio antes del despliegue en producción.

En cumplimiento del control A.8.15 (Registro de operaciones - Logging) de la ISO 27002:2022, el equipo de desarrollo deberá implementar una bitácora de auditoría inmutable en PostgreSQL que registre, como mínimo, los siguientes campos para cada operación sensible (creación o modificación de fixtures, resultados y datos de atletas):

Compo del Log	Descripción
user_id	Identificador del usuario autenticado que realizó la acción
ip_address	Dirección IP de origen de la solicitud
action	Tipo de operación ejecutada (INSERT, UPDATE, DELETE)
table_name	Entidad afectada (fixtures, results, players)
old_value	Estado del registro antes del cambio (formato JSON)
new_value	Estado del registro después del cambio (formato JSON)
timestamp	Fecha y hora exacta de la operación (UTC)

Los registros de esta tabla no deben ser modificables ni eliminables por ningún rol de usuario dentro del sistema, incluido el Administrador. Toda consulta de auditoría queda restringida al Responsable del SGSI / CISO y a la Alta Dirección, en cumplimiento del principio de no repudio establecido en la PSI.

- #### 4.2. Proceso ASMP (Application Security Management Process):
- El Proceso de Gestión de Seguridad de Aplicaciones (ASMP, por sus siglas en inglés) define el marco operativo bajo el cual el equipo de desarrollo de la AMPFS integra los controles de seguridad a lo largo del ciclo de vida del software, en cumplimiento del estándar ISO/IEC 27034. Para esta Asociación, el ASMP se implementa sobre el marco

de trabajo Scrum, adaptando los controles de seguridad a la cadencia de sprints del equipo.

4.2.1. Estructura del Proceso: Scrum como Marco de Implementación: El desarrollo del software de gestión de campeonatos se organiza bajo Scrum, donde cada sprint produce incrementos funcionales verificables. La seguridad no se trata como una fase independiente al final del desarrollo, sino como un conjunto de criterios de aceptación y compuertas técnicas que cada historia de usuario debe superar antes de considerarse completada (Definition of Done).

El equipo de desarrollo está conformado por los estudiantes Polo, Mendez, Vela y otros colaboradores, siendo el estudiante Polo el responsable designado de la revisión y aprobación de Pull Requests antes de cualquier fusión a las ramas protegidas.

4.2.2. Gestión de Ramas y Control de Cambios en GitHub: El repositorio del proyecto (frontend y backend) en GitHub implementa una estrategia de ramificación que constituye por sí misma un control de seguridad organizacional alineado al control A.8.32 (Gestión de cambios) de la ISO 27002:2022:

- **Ramas protegidas:** main, dev y SGSI. Ningún desarrollador puede hacer push directo a estas ramas.
- **Ramas de trabajo:** Cada desarrollador crea una rama específica por historia de usuario o tarea (feature branch), siguiendo la convención de nombrado vinculada al issue correspondiente (ej. MendezCreateInterfaceTeam).
- **Proceso de integración:** El desarrollador abre un Pull Request desde su rama de trabajo hacia la rama de destino indicada. El estudiante Polo actúa como revisor obligatorio (code reviewer), verificando tanto la correctitud funcional como el cumplimiento de los estándares de codificación segura definidos en la PSI (Parte C) antes de aprobar el merge.

Este flujo garantiza que ningún código no revisado llegue a los entornos de integración o producción, constituyendo una barrera humana de control que complementa los controles técnicos automatizados.

4.2.3. Estado Actual del Desarrollo y Controles por Módulo: A la fecha de elaboración del presente SGSI, el backend

NestJS cuenta con las siguientes historias de usuario completadas, cada una con sus implicaciones de seguridad correspondientes:

ID	Historias de Usuario	Control de Seguridad Aplicable
US-02	Gestión del ciclo de vida del campeonato (estados: en preparación, activa, finalizada)	RBAC: solo el Organizador puede cambiar estados. Guards NestJS por rol.
US-04	Conteo automático de equipos inscritos por categoría	Validación de integridad de datos con class-validator.
US-12	Registro de nuevos clubes	Validación de entradas y unicidad de registros en PostgreSQL vía TypeORM.
US-13	Validación de requisitos de jugadores por categoría (edad, género, nivel)	Validación de PII sensible; acceso restringido al Organizador.
US-14	Verificación de duplicidad de inscripción de jugadores	Control de integridad referencial en la base de datos.
US-17	Inscripción definitiva de equipos en el campeonato	Registro auditable; punto de entrada de datos financieros (número de transacción).
US-21	Evaluación de solicitudes de permiso de equipos	Control de acceso: solo el Organizador gestiona aprobaciones/rechazos.
US-22	Registro de decisión de permiso (aprobación/rechazo)	Trazabilidad de decisiones — insumo directo para el Audit Log (punto 4.1.6).
US-26	Publicación de programación de partidos (fixtures)	Control crítico: mitigación de R01 — solo el Organizador puede publicar.
US-36	Eliminación automática de equipos con 2 W.O. acumulados	Lógica de negocio automatizada; debe ser auditable e irreversible sin autorización.
US-37	Notificación al jugador sobre doble partido por permiso	Dato informativo; no expone PII adicional al propio jugador autenticado.

Las siguientes historias están en desarrollo activo y completarán el núcleo funcional del sistema:

ID	Historias de Usuario	Control de Seguridad Aplicable
US-30	Programación de partidos (fecha, hora, cancha, categoría)	Protección de fixtures contra modificación no autorizada — riesgo R01.
US-33	Registro de resultados de partidos	Punto más crítico: activación obligatoria del Audit Log (A.8.15).
US-34	Actualización automática de tabla de posiciones	Integridad automática: no debe ser editable manualmente por ningún rol.

4.2.4. Compuertas de Seguridad por Sprint (Security Gates):

Antes de que cualquier incremento sea promovido a la rama dev o main, el Pull Request debe superar las siguientes

compuertas mínimas de seguridad, verificadas por el revisor designado (Polo):

- **Compuerta 1 - Validación de entradas:** ¿Todos los DTOs del endpoint nuevo usan class-validator? ¿No existen raw queries en el servicio o repositorio?
- **Compuerta 2 - Control de acceso:** ¿El endpoint está protegido por el Guard JWT correspondiente? ¿El decorador de rol restringe el acceso al perfil correcto (Admin, Organizador, Jugador)?
- **Compuerta 3 - Gestión de secretos:** ¿Ninguna variable de entorno sensible está hardcodeada en el código? ¿No hay datos expuestos con NEXT_PUBLIC_ en el frontend?
- **Compuerta 4 - Análisis de dependencias:** ¿Se ejecutó pnpm audit y no hay vulnerabilidades high o critical sin resolver?

El incumplimiento de cualquiera de estas compuertas bloquea el merge hasta que el desarrollador corrija las observaciones y solicite una nueva revisión.

4.3. Definición del Target LoA (Level of Assurance): El Nivel de Garantía de Seguridad (LoA, *Level of Assurance*) es el indicador que establece, según la ISO/IEC 27034, cuán rigurosamente debe ser protegida una aplicación en función de los datos que gestiona, los riesgos identificados y el perfil de sus usuarios. La escala va del **LoA 1** (aplicaciones informativas sin datos sensibles) al **LoA 5** (sistemas críticos nacionales o financieros de alto impacto).

4.3.1. Factores de Análisis para la Determinación del LoA: Para determinar el LoA objetivo del sistema de gestión de la AMPFS, se analizan los siguientes factores concretos del proyecto:

Factor 1 - Tipo y sensibilidad de los datos gestionados

El sistema almacena y procesa datos personales identificables (PII) de los atletas que incluyen: nombre completo, número de C.I., fecha de nacimiento, fotografía y número de teléfono celular. Estos datos están protegidos por la Ley N° 164 y la ISO/IEC 27018, lo que eleva el nivel de exigencia de seguridad requerido.

Factor 2 - Modelo de acceso y exposición pública

La aplicación opera bajo un modelo de acceso diferenciado en tres niveles:

- **Público general (sin registro):** Puede consultar información como fixtures publicados y resultados. No accede a PII.
- **Jugadores registrados:** Tienen cuenta propia y acceden a vistas adicionales de su perfil e historial. Manejan sus propios datos PII.
- **Organizador:** Único rol administrativo con acceso total al sistema. Su cuenta es privada y de acceso restringido. Gestiona los datos de todos los atletas y la integridad de los resultados.

La existencia de una porción pública accesible desde internet incrementa la superficie de ataque, aunque el núcleo sensible esté protegido por autenticación.

Factor 3 — Naturaleza de las transacciones financieras

El sistema no procesa pagos en línea ni integra pasarelas de cobro. El módulo financiero registra el número de comprobante de transferencia QR o pago en efectivo como dato de trazabilidad. Esto limita el riesgo financiero directo, aunque no elimina el riesgo de alteración de registros de inscripción (R15).

Factor 4 — Riesgos críticos identificados

La Matriz de Riesgos del Capítulo III identificó 6 riesgos en nivel Crítico, entre los que destacan la manipulación de fixtures (R01), la inyección SQL (R03) y la pérdida total del VPS (R10). La presencia de riesgos críticos asociados a integridad deportiva e institucional eleva el LoA requerido.

4.3.2. LoA Asignado: Nivel 3: Considerando los cuatro factores anteriores, la Asociación Municipal de Pelota Frontón Sucre establece un Target LoA de Nivel 3 para su sistema de gestión de campeonatos, definido de la siguiente manera:

Criterio	Descripción para el sistema AMPFS
Nivel asignado	LoA 3 - Seguridad robusta con controles técnicos verificables
Justificación	Gestión de PII sensible (foto, C.I., celular) + riesgos críticos de integridad identificados + acceso parcialmente público desde internet
Exclusión de LoA 4 - 5	El sistema no procesa pagos directos, no maneja infraestructura crítica nacional ni datos médicos de alta sensibilidad
Exclusión de LoA 1 - 2	La presencia de PII de atletas, el impacto institucional de una brecha y los 6 riesgos críticos identificados descartan niveles bajos

Las implicaciones prácticas del LoA 3 para el equipo de desarrollo son las siguientes:

Autenticación: Tokens JWT con firma verificada son obligatorios. Se recomienda MFA o Google OAuth 2.0 para el rol Organizador como control adicional dado el nivel de privilegio que concentra.

Autorización: RBAC implementado mediante Guards NestJS en todos los endpoints que manejen PII o datos de fixtures y resultados.

Cifrado en tránsito: Comunicación HTTPS/TLS obligatoria entre el cliente y el servidor VPS. Prohibido el uso de HTTP en producción.

Integridad de datos: Audit Log inmutable (punto 4.1.6) obligatorio antes del despliegue productivo, especialmente para las historias US-33 y US-34 aún en desarrollo.

Gestión de vulnerabilidades: pnpm audit y análisis SAST obligatorios por sprint, como compuerta de seguridad previa al merge a ramas protegidas.

Privacidad: El acceso a los datos personales completos de un jugador (foto, celular, C.I.) debe estar restringido estrictamente al Organizador, nunca expuesto en las vistas públicas ni en las vistas de otros jugadores.

- 4.4. Controles de Seguridad de Aplicación (ASC):** Los Controles de Seguridad de Aplicación (ASC, Application Security Controls) representan el conjunto de salvaguardas técnicas concretas que el sistema de gestión de campeonatos de la AMPFS implementa o debe implementar para alcanzar el Target LoA 3 definido en el punto anterior. Cada ASC se deriva directamente de los riesgos críticos identificados en el Capítulo III y se mapea al control correspondiente de la ISO 27002:2022.

4.4.1. ASC-01 - Configuración de Cabeceras de Seguridad

HTTP (Helmet): Control ISO 27002: A.8.20 - Seguridad en redes / A.8.25 — Desarrollo web seguro

Estado: Implementado, **Riesgo mitigado:** R02 (ataques web automatizados), R03 (inyección de código)

El backend NestJS implementa el middleware Helmet en el punto de entrada principal de la aplicación (main.ts), activándose sobre todas las rutas antes de que cualquier solicitud llegue a los controladores. La configuración actual es la siguiente:

```
app.use(helmet({
  crossOriginResourcePolicy: false
}));
```

Helmet configura automáticamente las siguientes cabeceras de seguridad HTTP en cada respuesta del servidor:

Cabecera HTTP	Protección que ofrece
Content-Security-Policy	Previene ataques XSS bloqueando scripts no autorizados
X-Frame-Options	Previene ataques de Clickjacking al prohibir el embebido en iframes
X-Content-Type-Options	Evita que el navegador interprete archivos con un MIME type incorrecto
Strict-Transport-Security	Fuerza conexiones HTTPS, bloqueando degradaciones a HTTP inseguro
X-DNS-Prefetch-Control	Controla el prefetch de DNS para reducir filtraciones de información

La opción `crossOriginResourcePolicy: false` está justificada para permitir que el frontend Next.js consuma recursos del API desde un origen diferente durante el desarrollo. Para el despliegue en producción, este parámetro deberá revisarse y configurarse con la política same-site o cross-origin según el dominio final del VPS, constituyendo una tarea pendiente del equipo antes del lanzamiento.

- 4.4.2. ASC-02 - Control de Orígenes Permitidos (CORS):**
Control ISO 27002: A.8.20 - Seguridad en redes, **Estado:** Parcialmente implementado — requiere ajuste para producción, **Riesgo mitigado:** R02 (acceso no autorizado desde orígenes externos)

El backend implementa CORS mediante la configuración nativa de NestJS, restringiendo los orígenes que pueden realizar solicitudes al API:

```
app.enableCors({
  origin: process.env.FRONTEND_API_URL
});
```

El origen permitido se lee de la variable de entorno `FRONTEND_API_URL`, lo cual es una práctica correcta de gestión de secretos. Sin embargo, se identifican dos observaciones de seguridad:

- **Observación 1:** En el entorno de desarrollo local actual, la variable `FRONTEND_API_URL` no está definida en el `.env` del equipo, por lo que el sistema recae en el origen comentado `localhost:3000`. Esto es aceptable en desarrollo pero debe ser corregido formalmente antes del despliegue.
- **Observación 2:** La configuración de producción debe definir explícitamente el dominio del frontend desplegado en el VPS como único origen válido, rechazando cualquier solicitud proveniente de dominios no autorizados.

Acción requerida antes del despliegue: Definir `FRONTEND_API_URL` con el dominio real de producción en el `.env` del servidor VPS y verificar que ningún otro origen sea aceptado.

- 4.4.3. ASC-03 - Validación Global de Entradas (ValidationPipe):**
Control ISO 27002: A.8.28 — Codificación segura / A.8.27 — Validación de entradas, **Estado:** Implementado, **Riesgo mitigado:** R03 (inyección SQL), R04 (pérdida de integridad por concurrencia)
 El backend aplica un `ValidationPipe` de forma global sobre todos los endpoints de la aplicación:

```
app.useGlobalPipes(new ValidationPipe({  
  disableErrorMessages: false }));
```

Esta configuración garantiza que toda solicitud entrante sea validada automáticamente contra el DTO correspondiente antes de llegar a la capa de negocio. Los decoradores de `class-validator` en cada DTO (por ejemplo `@IsString()`, `@IsEmail()`, `@IsNotEmpty()`, `@IsDateString()`) rechazan cualquier dato malformado con una respuesta de error estructurada, sin exponer detalles internos del sistema.

Nota de seguridad: La opción `disableErrorMessages: false` permite que los mensajes de error de validación sean visibles en la respuesta. Para producción se recomienda evaluar cambiar esto a `true` o personalizar los mensajes para no revelar la estructura interna de los DTOs al atacante, constituyendo una mejora de hardening pendiente.

- 4.4.4. ASC-04 - Autenticación mediante JWT y Documentación Segura de la API:** Control ISO 27002: A.8.12 — Gestión de privilegios de acceso / A.5.15 — Control de acceso, **Estado:** Implementado, **Riesgo mitigado:** R01 (modificación intencionada de fixtures), R02 (acceso no autorizado).

El sistema implementa autenticación basada en tokens JWT (JSON Web Tokens) mediante `@nestjs/jwt ^11.0.2` y `@nestjs/passport ^11.0.5`. Cada token es firmado con el `JWT_SECRET` definido como variable de entorno en el servidor, nunca expuesto en el código fuente ni en el repositorio de GitHub.

La documentación interactiva del API (Swagger/OpenAPI), disponible en la ruta `/api`, está configurada con autenticación Bearer JWT obligatoria para todos los endpoints:

```
.addBearerAuth({ type: 'http', scheme: 'bearer',  
bearerFormat: 'JWT', in: 'header' }, 'access-token')  
.addSecurityRequirements('access-token')
```

Esto garantiza que la documentación del API no pueda ser utilizada para ejecutar operaciones reales sin un token válido, evitando que Swagger se convierta en un vector de ataque en entornos expuestos.

Acción requerida para producción: El endpoint `/api` (Swagger UI) debe ser deshabilitado o protegido por IP en el entorno de producción del VPS, ya que expone la estructura completa del API públicamente. Esto se puede controlar mediante una variable de entorno:

```
if (process.env.NODE_ENV !== 'production') {  
  SwaggerModule.setup('api', app, document);  
}
```

- 4.4.5. ASC-06 - Prevención de Inyección SQL mediante TypeORM:** Control ISO 27002: A.8.28 — Codificación segura, **Estado:** Implementado como política obligatoria, **Riesgo mitigado:** R03 (inyección de código malicioso en la base de datos).

Toda interacción con la base de datos PostgreSQL se realiza exclusivamente a través de TypeORM, prohibiendo el uso de consultas SQL crudas (raw queries) en cualquier repositorio

o servicio del backend. TypeORM parametriza automáticamente los valores de las consultas, neutralizando los ataques de inyección SQL a nivel de la capa de persistencia.

Esta política es una compuerta de seguridad obligatoria verificada por el revisor (Polo) en cada Pull Request, conforme al proceso ASMP definido en el punto 4.2.

4.4.6. ASC-05 - Versionado y Prefijo Global del API: Control ISO 27002: A.8.25 — Desarrollo web seguro, **Estado:** Implementado, **Riesgo mitigado:** R02 (superficie de ataque reducida):

El API implementa un prefijo global /api/v1 en todas sus rutas:

```
app.setGlobalPrefix('api/v1');
```

Este control, aunque habitualmente asociado a buenas prácticas de diseño, tiene implicaciones de seguridad directas: reduce la superficie de ataque al hacer que las rutas del sistema no sean predecibles mediante patrones genéricos, y facilita la implementación futura de reglas de firewall o WAF (Web Application Firewall) en el VPS que filtren exclusivamente el tráfico dirigido al prefijo oficial, bloqueando cualquier intento de acceso a rutas no versionadas.

4.4.7. Gestión de Secretos y Variables de Entorno: Control ISO 27002: A.8.10 — Gestión de información sensible, **Estado:** Implementado, **Riesgo mitigado:** R01, R03 (compromiso de credenciales).

Todas las credenciales sensibles del sistema se gestionan exclusivamente mediante variables de entorno, nunca hardcodeadas en el código fuente:

- JWT_SECRET — Clave de firma de tokens JWT
- PGSQL_PASSWORD — Credencial de acceso a PostgreSQL
- FRONTEND_API_URL — Origen permitido para CORS
- PORT — Puerto de escucha del servidor

El archivo .env está excluido del repositorio GitHub mediante .gitignore, garantizando que las credenciales no sean versionadas ni expuestas públicamente.

Observación resuelta: Durante la elaboración del presente SGSI se detectó que el .env de desarrollo contenía credenciales reales. El equipo procedió inmediatamente a la rotación del JWT_SECRET y la contraseña de PostgreSQL, constituyendo este evento un ejercicio práctico de respuesta ante incidentes alineado al procedimiento de gestión de no conformidades de la PSI.

4.4.8. Resumen del Estado de los ASC

ASC	Control	Estado	Prioridad
ASC-01	Cabeceras de seguridad HTTP (Helmet)	Implementado	Revisar crossOriginResourcePolicy en producción
ASC-02	Control de orígenes CORS	Parcial	Definir FRONTEND_API_URL en VPS antes del despliegue
ASC-03	Validación global de entradas (ValidationPipe)	Implementado	Evaluar disableErrorMessage: true en producción
ASC-04	Autenticación JWT + Swagger seguro	Implementado	Deshabilitar Swagger en producción
ASC-05	Prefijo global /api/v1	Implementado	-
ASC-06	Prevención de inyección SQL (TypeORM)	Implementado	Mantener como compuerta obligatoria en PR
ASC-07	Gestión de secretos y variables de entorno	Implementado	-
ASC-08	Audit Log inmutable (PostgreSQL)	Pendiente	Crítico — obligatorio antes de US-33 y US-34

El ASC-08 (Audit Log) se mantiene como el único control crítico pendiente de implementación, cuyo diseño fue detallado en el punto 4.1.6 y cuya activación es condición bloqueante para el despliegue de las historias US-33 (registro de resultados) y US-34 (actualización de tabla de posiciones), las dos funcionalidades de mayor riesgo institucional del sistema.

4.5. Seguridad de Red e Infraestructura: Este apartado define los controles de seguridad aplicados sobre la infraestructura de red y los componentes de despliegue del sistema de gestión de campeonatos de la AMPFS, abarcando tanto la red local de la sede administrativa en el Estadio Patria como el entorno del Servidor Virtual Privado (VPS)

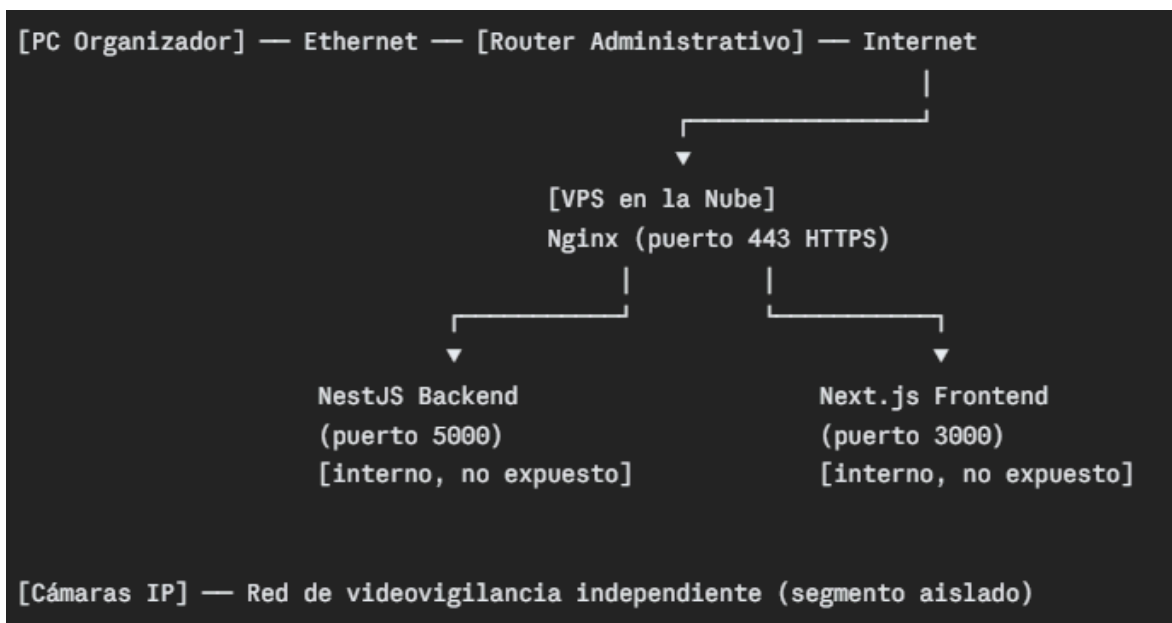
en la nube. Los controles aquí definidos se alinean con la norma ISO/IEC 27033 (Seguridad de Redes) y complementan los ASC definidos en el punto anterior.

4.5.1. Arquitectura General de Red: El sistema opera bajo un modelo de infraestructura híbrida compuesto por dos segmentos claramente diferenciados:

- **Segmento local (LAN):** La sede administrativa ubicada en la Puerta 18 del Estadio Patria, donde opera la PC de escritorio del organizador conectada mediante cable Ethernet a un router doméstico de uso exclusivo administrativo.
- **Segmento en la nube (VPS):** El servidor virtual privado donde se despliegan el backend NestJS y el frontend Next.js, accesible desde internet bajo protocolo HTTPS.

Ambos segmentos se comunican a través de internet mediante conexiones cifradas, nunca mediante canales no autenticados o en texto plano.

El diagrama lógico de la arquitectura es el siguiente:



4.5.2. Controles de Seguridad de la Red Local (LAN): Control ISO 27002: A.8.20 — Seguridad en redes / A.7.1 — Perímetro de seguridad físico.

Riesgo mitigado: R13 (interceptación de credenciales de red), R14 (caída del servicio durante registros)

La red local de la sede administrativa opera con un router doméstico de uso exclusivo para la gestión interna de la Asociación. Dado el contexto institucional de la AMPFS — una oficina pequeña cuyo único usuario operativo es el organizador — este dispositivo cumple una función de conectividad acotada y controlada. Los siguientes controles se aplican sobre esta infraestructura:

- **Acceso exclusivo por cable Ethernet**
La PC del organizador se conecta al router mediante cable Ethernet, eliminando la superficie de ataque asociada a redes inalámbricas para el equipo de trabajo principal. No existe red Wi-Fi administrativa de uso general; los jugadores y público no tienen acceso a la red del Estadio Patria, lo que reduce significativamente el riesgo de interceptación de credenciales (R13).
- **Configuración mínima requerida del router**
Aunque el dispositivo es de gama doméstica, deben aplicarse las siguientes configuraciones de hardening como requisito mínimo de seguridad:

Configuración	Acción requerida	Justificación
Credenciales de administración	Cambiar usuario y contraseña por defecto del panel del router	Las credenciales de fábrica son públicamente conocidas
Firmware	Mantener actualizado a la última versión disponible del fabricante	Parchar vulnerabilidades conocidas del dispositivo
Acceso remoto al panel	Deshabilitar la administración remota desde internet	Evitar exposición del panel de configuración fuera de la LAN
Red Wi-Fi (si existe)	Protocolo WPA3 o mínimo WPA2 con contraseña robusta	Proteger el canal inalámbrico si se habilita en el futuro
DHCP	Asignar IP estática a la PC del organizador	Facilitar reglas de control de acceso por dirección IP

- **IP estática para la PC del organizador**
Como control adicional alineado al principio de mínimo privilegio, la PC del organizador debe operar con una dirección IP estática asignada en el router. Esto permite que el panel de administración del sistema web pueda configurarse en el VPS para aceptar solicitudes de gestión únicamente desde esta IP conocida, añadiendo una capa de control de acceso por red sobre la autenticación JWT ya implementada.

4.5.3. Sistema de Videovigilancia IP: Control ISO 27002: A.7.4
— Monitoreo de seguridad física.

Riesgo mitigado: R06 (hurto o fuga de datos personales desde la oficina), R07 (extravío de planillas físicas).

El sistema de cámaras IP instalado en el recinto del Estadio Patria opera sobre una red de videovigilancia independiente y físicamente aislada de la red administrativa del organizador. Este aislamiento es un control de seguridad crítico que evita que un eventual compromiso del sistema de cámaras pueda utilizarse como vector de acceso a la red donde opera la PC administrativa o hacia el VPS.

Las grabaciones del sistema de videovigilancia cubren las áreas de custodia de activos físicos sensibles (oficina administrativa, archivadores de Kardex y planillas), sirviendo como respaldo de auditoría ante incidentes de seguridad física, en línea con el mecanismo de no repudio definido en la PSI.

4.5.4. Arquitectura de Despliegue en el VPS — Nginx como Reverse Proxy: Control ISO 27002: A.8.20 — Seguridad en redes / A.8.21 — Seguridad de servicios de red, **Estado:** Propuesto — pendiente de implementación al momento del despliegue, **Riesgo mitigado:** R09 (secuestro de datos por ciberataque), R10 (pérdida total del VPS).

Se establece como arquitectura de despliegue oficial del VPS la implementación de Nginx como servidor web y reverse proxy, constituyendo la única puerta de entrada al sistema desde internet. Bajo esta arquitectura, ningún proceso de la aplicación (NestJS en puerto 5000, Next.js en puerto 3000) queda expuesto directamente a internet; todo el tráfico es recibido y gestionado por Nginx en los puertos estándar.

Justificación de la elección de Nginx:

Nginx es una solución de código abierto (open-source), gratuita y ampliamente probada en entornos de producción, lo que la hace compatible con la limitación económica del proyecto documentada en el Capítulo I. Su adopción no representa costo adicional para la Asociación.

La configuración de Nginx para el despliegue deberá implementar los siguientes bloques de control:

- **Redirección forzada de HTTP a HTTPS**

Todo tráfico entrante en el puerto 80 (HTTP) debe ser redirigido automáticamente al puerto 443 (HTTPS), garantizando que ninguna comunicación viaje en texto plano:

```
server {
    listen 80;
    server_name dominio-ampfs.com;
    return 301 https://$host$request_uri;
}
```

- **Terminación SSL/TLS con certificado Let's Encrypt**
El certificado SSL será gestionado mediante Let's Encrypt, autoridad certificadora gratuita y reconocida internacionalmente, a través de la herramienta Certbot. Esto garantiza comunicaciones cifradas bajo HTTPS sin costo adicional para la Asociación:

```
server {
    listen 443 ssl;
    server_name dominio-ampfs.com;

    ssl_certificate
/etc/letsencrypt/live/dominio-
ampfs.com/fullchain.pem;
    ssl_certificate_key
/etc/letsencrypt/live/dominio-
ampfs.com/privkey.pem;

    # Backend NestJS
    location /api/ {
        proxy_pass http://localhost:5000;
    }

    # Frontend Next.js
    location / {
        proxy_pass http://localhost:3000;
    }
}
```

- **Protección del puerto SSH**
El acceso administrativo al VPS mediante SSH debe reforzarse con los siguientes controles mínimos, mitigando el riesgo R09 identificado en la Matriz de Riesgos:

Control SSH	Configuración requerida
-------------	-------------------------

Puerto por defecto	Cambiar el puerto 22 a un puerto no estándar (ej. 2222 o superior)
Autenticación	Deshabilitar autenticación por contraseña; usar exclusivamente par de claves SSH (pública/privada)
Acceso root	Deshabilitar login directo como root (PermitRootLogin no)
Firewall (UFW)	Permitir únicamente los puertos 80, 443 y el puerto SSH personalizado

- 4.5.5. Cifrado en Tránsito y Política HTTPS:** Control ISO 27002: A.8.24 — Uso de criptografía, **Estado:** Propuesto — condición obligatoria para el despliegue en producción, **Riesgo mitigado:** R09 (intercepción de datos en tránsito), R13 (intercepción de credenciales).

El sistema establece como política de seguridad obligatoria e irrenunciable que toda comunicación entre el cliente (navegador/dispositivo del jugador u organizador) y el servidor VPS se realice exclusivamente bajo protocolo HTTPS con TLS 1.2 o superior. Esta política aplica sin excepción a todos los entornos de acceso, incluyendo dispositivos móviles desde los cuales los jugadores consultarán la aplicación.

La combinación de Nginx como reverse proxy, el certificado SSL de Let's Encrypt y la cabecera Strict-Transport-Security configurada por Helmet (ASC-01) forma una cadena de controles que garantiza el cifrado de extremo a extremo en todas las comunicaciones del sistema, protegiendo los datos personales (PII) de los atletas durante su transmisión conforme a los requisitos de la ISO/IEC 27018.

- 4.5.6. Copias de Seguridad Automatizadas del VPS:** Control ISO 27002: A.8.13 — Copias de seguridad, **Estado:** Propuesto — pendiente de implementación, **Riesgo mitigado:** R10 (pérdida total del VPS por fallo técnico o borrado accidental — nivel Crítico = 20).

Como complemento a los controles de red, y dado que el riesgo R10 fue identificado como el de mayor puntuación en la Matriz de Riesgos del Capítulo III, se establece la siguiente política de respaldos automatizados para el VPS:

- **Frecuencia:** Cron Job diario programado en horario de baja actividad (ej. 02:00 AM hora Bolivia).
- **Contenido del respaldo:** Dump completo de la base de datos PostgreSQL (pg_dump) y archivos de configuración del servidor.

- **Cifrado:** El archivo de respaldo debe cifrarse antes de su transferencia al almacenamiento externo.
- **Destino:** Almacenamiento en la nube aislado y externo al VPS principal (ej. bucket S3 de AWS, Google Cloud Storage u equivalente del proveedor VPS seleccionado).
- **Retención:** Mínimo 30 días de historial de respaldos disponibles para restauración.
- **Verificación:** Restauración de prueba mensual para validar la integridad de los respaldos almacenados.

4.5.7. Resumen de Controles de Red e Infraestructura:

Control	Ámbito	Estado
Conexión Ethernet exclusiva para PC del organizador	LAN — Estadio Patria	Implementado
Sin acceso Wi-Fi para jugadores o público	LAN — Estadio Patria	Implementado
IP estática para PC del organizador	LAN — Estadio Patria	Pendiente de configuración
Hardening del router doméstico	LAN — Estadio Patria	Pendiente de configuración
Red de videovigilancia IP aislada	Física — Estadio Patria	Implementado
Nginx como reverse proxy	VPS — Nube	Propuesto para despliegue
HTTPS/TLS con Let's Encrypt (Certbot)	VPS — Nube	Propuesto para despliegue
Redirección forzada HTTP → HTTPS	VPS — Nube	Propuesto para despliegue
Hardening SSH (puerto, claves, sin root)	VPS — Nube	Propuesto para despliegue
Firewall UFW (puertos 80, 443, SSH)	VPS — Nube	Propuesto para despliegue
Copias de seguridad automatizadas (Cron + pg_dump)	VPS — Nube	Propuesto para despliegue

VI. CAPITULO V: SOPORTE, CONTINUIDAD Y MEDICIÓN (ISO 27031 y 27004)

5.1. Concienciación y Comunicación: La concienciación en seguridad de la información constituye uno de los pilares fundamentales del SGSI, reconocida explícitamente en la cláusula 7.3 de la norma ISO/IEC 27001:2022. Para la Asociación Municipal de Pelota Frontón Sucre, este pilar adquiere especial relevancia dado que el análisis DAFO del Capítulo I identificó la brecha de competencia digital de la directiva

como una de las debilidades internas más críticas del sistema. Sin usuarios conscientes de sus responsabilidades de seguridad, ningún control técnico definido en el Capítulo IV es suficiente por sí solo.

5.1.1. Diagnóstico del Nivel de Concienciación Actual: Antes de definir el programa de concienciación, se establece el estado actual de conocimiento en seguridad de la información dentro de la Asociación:

Actor	Nivel de concienciación actual	Observación
Organizador	Medio — capacitado durante el desarrollo del proyecto	Único usuario con exposición previa a conceptos del SGSI
Presidente	Básico — conocimiento general sin formación técnica formal	Comprende la importancia del SGSI a nivel institucional
Resto de la directiva	Nulo — primera exposición al tema	Requiere programa de formación inicial prioritario
Jugadores registrados	Nulo — sin política de privacidad comunicada aún	Requiere aviso formal al momento del registro en el sistema
Delegados y clubes	Nulo — acceden al sistema como usuarios sin capacitación	Requieren comunicación básica de uso seguro

Este diagnóstico confirma que el programa de concienciación debe diseñarse en niveles diferenciados según el rol y el grado de interacción de cada actor con el sistema.

5.1.2. Programa de Concienciación en Seguridad de la Información: El programa se estructura en tres niveles de formación, adaptados a la realidad institucional de la Asociación y a sus limitaciones de recursos definidas en el Capítulo I.

Nivel 1 — Alta Dirección (Presidente y Directiva)

Objetivo: Que la directiva comprenda su rol como garante institucional del SGSI y las implicaciones legales del manejo de datos personales bajo la Ley N° 164.

Contenido mínimo:

- Qué es el SGSI y por qué protege la imagen institucional de 62 años de la Asociación.
- Responsabilidades legales del manejo de datos personales (PII) de los atletas bajo la Ley N° 164.
- Qué constituye un incidente de seguridad y cómo reportarlo (filtración de fixtures, acceso no autorizado al sistema).

- **Prohibiciones básicas:** compartir credenciales, enviar fixtures por WhatsApp antes de su publicación oficial, fotografiar planillas físicas sin autorización.

Modalidad: Reunión presencial de no más de 90 minutos, conducida por el Responsable del SGSI, apoyada en material visual simplificado. Se priorizará la reunión presencial como canal principal dado que es el mecanismo de comunicación institucional ya establecido en la Asociación.

Frecuencia: Una sesión inicial obligatoria antes del despliegue del sistema en producción, con una sesión de actualización anual coincidente con la revisión del SGSI por la dirección.

Nivel 2 — Organizador del Campeonato

Objetivo: Reforzar y formalizar los conocimientos adquiridos durante el desarrollo del proyecto, estableciendo procedimientos operativos de seguridad concretos para el uso diario del sistema.

Contenido mínimo:

- **Gestión segura de credenciales:** no compartir la contraseña del panel de administración bajo ninguna circunstancia, incluso con miembros de la directiva.
- Procedimiento correcto de cierre de sesión al abandonar la PC administrativa.
- Protocolo de digitalización inmediata de planillas físicas al finalizar cada partido (mitigación de R07).
- Reconocimiento de intentos de ingeniería social: solicitudes inusuales de acceso al sistema, mensajes sospechosos por WhatsApp solicitando credenciales.
- Procedimiento de reporte de incidentes al Responsable del SGSI.

Modalidad: Sesión práctica individual con el sistema real, conducida por el equipo de desarrollo. Complementada con una guía de usuario seguro en formato impreso disponible en la oficina administrativa.

Frecuencia: Sesión de refuerzo semestral y cada vez que se incorpore una funcionalidad nueva al sistema.

Nivel 3 — Jugadores Registrados y Usuarios del Sistema

Objetivo: Informar a los jugadores sobre el tratamiento de sus datos personales y sus derechos como titulares de la información, en cumplimiento de la Ley N° 164 y la ISO/IEC 27018.

Contenido mínimo:

- Qué datos personales recopila el sistema (nombre, C.I., fecha de nacimiento, fotografía, número de celular).
- Con qué finalidad se recopilan y quién tiene acceso a ellos dentro de la Asociación.
- Derechos del jugador sobre sus propios datos (consulta, corrección).
- Medidas de seguridad que la Asociación aplica para proteger su información.

Canal de comunicación: Política de Privacidad integrada en el frontend del sistema, presentada como paso obligatorio durante el proceso de registro de cuenta. El jugador deberá confirmar su lectura mediante un checkbox de aceptación explícita antes de completar el registro. Su implementación en el frontend es un control pendiente de carácter obligatorio antes del despliegue en producción, equivalente en prioridad al Audit Log definido en el punto 4.1.6.

5.1.3. Canales de Comunicación del SGSI: La gestión de la comunicación interna del SGSI se estructura sobre los canales que la Asociación ya utiliza institucionalmente, sin imponer herramientas nuevas que generen resistencia operativa:

Canal	Uso actual	Uso dentro del SGSI
Whatsapp	Comunicación general entre directiva, organizador y delegados	Notificaciones operativas urgentes (ej. incidente detectado, caída del sistema). Se prohíbe explícitamente el envío de fixtures, credenciales o datos personales de jugadores por este canal
Reuniones presenciales	Asambleas y coordinación de campeonatos	Canal principal para capacitaciones de concienciación, revisiones del SGSI y comunicación de incidentes formales

Restricción crítica sobre WhatsApp: Dado que WhatsApp es el canal de comunicación predominante en la Asociación, se establece como norma de obligatorio cumplimiento que ningún dato clasificado como sensible — incluyendo fixtures no publicados oficialmente, credenciales de acceso al sistema, datos personales de jugadores o resoluciones disciplinarias de la Comisión Técnica — sea transmitido por este canal. La filtración de esta información por WhatsApp constituye el escenario de riesgo conocido institucionalmente como el "teje", catalogado como riesgo crítico R01 en la Matriz de Riesgos del Capítulo III.

5.1.4. Canal de Reporte de Incidentes: Actualmente la Asociación no dispone de un mecanismo formal para que jugadores, delegados o usuarios del sistema reporten eventos de seguridad sospechosos. Esta ausencia representa una brecha operativa del SGSI que debe ser resuelta antes del despliegue en producción.

Se establece el siguiente procedimiento básico de reporte de incidentes, diseñado para ser operativo dentro de las capacidades reales de la institución:

¿Qué debe reportarse?

- Acceso no autorizado o sospechoso al sistema.
- Modificación de resultados o fixtures sin autorización conocida.
- Recepción de mensajes solicitando credenciales de acceso.
- Visualización de datos personales de otros jugadores sin justificación.
- Caída o comportamiento anómalo del sistema durante un campeonato activo.

¿A quién reportar?

Quien detecta el incidente	A quien reporta	Canal
Organizador	Responsable del SGSI / CISO	Directo — presencial o llamada
Jugador o usuario del sistema	Organizador	WhatsApp institucional de la Asociación
Miembro de la directiva	Presidente y Responsable del SGSI	Reunión presencial o llamada

Tiempo de respuesta esperado: El Responsable del SGSI deberá acusar recibo del reporte en un plazo máximo de 24 horas y activar el procedimiento de acción correctiva definido en la PSI (Parte D) si el incidente es confirmado.

Implementación en el sistema: Se propone incorporar en el frontend un enlace o formulario de contacto visible para usuarios autenticados, que dirija el reporte al canal institucional de la Asociación, como mejora futura de la plataforma.

- 5.2. Continuidad TIC (DRP):** El Plan de Recuperación ante Desastres (DRP, Disaster Recovery Plan) define los procedimientos, tiempos objetivo y responsabilidades que permiten a la Asociación Municipal de Pelota Frontón Sucre restaurar la operatividad de su sistema de gestión de campeonatos ante eventos de interrupción, en cumplimiento del estándar ISO/IEC 27031 (Directrices para la preparación de las TIC para la continuidad del negocio).

5.2.1. Contexto Operativo y Ventana Crítica de Operación: Para definir los parámetros del DRP con precisión, es fundamental comprender el ciclo operativo real de la Asociación. A diferencia de sistemas de negocio continuo, el software de gestión de campeonatos de la AMPFS opera bajo un patrón de uso concentrado en fines de semana, específicamente sábados y domingos durante la temporada de campeonato activo.

Este patrón define una ventana crítica de operación que es el periodo durante el cual una caída del sistema genera el mayor impacto institucional:

Periodo	Nivel de criticidad	Descripción
Sábado y domingo (día de partidos)	Critico	El organizador consulta fixtures, registra permisos y actualiza resultados. Una caída afecta directamente la transparencia del campeonato
Lunes a viernes	Moderado	El organizador puede programar partidos y gestionar inscripciones. Una caída es tolerable con mayor margen de recuperación
Fuera de temporada	Bajo	Sin campeonato activo, el sistema no es operativamente crítico

Un factor mitigante fundamental identificado en la operación real de la Asociación es que los resultados de los partidos

son registrados físicamente por el árbitro en las planillas de control al finalizar cada encuentro, antes de ser ingresados al sistema por el organizador. Esto significa que una caída del sistema durante un día de partidos no genera pérdida de información, ya que el dato fuente siempre existe en soporte físico. El organizador puede ingresar los resultados al sistema incluso días después de jugados los partidos sin comprometer la integridad de la información.

5.2.2. Parámetros Objetivo del DRP: Basándose en el contexto operativo anterior, se definen los siguientes parámetros estándar de recuperación para el SGSI de la AMPFS:

Parametro	Definición	Valor objetivo para la AMPFS
RTO (Recovery Time Objective)	Tiempo máximo tolerable de inactividad del sistema antes de que el impacto sea inaceptable	24 horas
RPO (Recovery Point Objective)	Antigüedad máxima aceptable de los datos restaurados tras una pérdida	24 horas
MTTR (Mean Time To Recover)	Tiempo promedio esperado para restaurar el servicio tras un incidente	4 horas

Justificación del RTO de 24 horas: Dado que los campeonatos se juegan únicamente los fines de semana y los resultados siempre quedan respaldados en planillas físicas firmadas por árbitros y jugadores, el sistema puede estar inactivo hasta 24 horas sin que se pierda información ni se detenga la operación deportiva. Este margen permite al administrador del sistema diagnosticar y resolver el incidente sin presión operativa inmediata.

Justificación del RPO de 24 horas: Con la política de respaldos automatizados diarios definida en el punto 4.5.6 (Cron Job nocturno a las 02:00 AM), el peor escenario de pérdida de datos corresponde a las operaciones del día anterior, las cuales pueden ser reconstruidas a partir de las planillas físicas custodiadas por el organizador.

5.2.3. Inventario de Componentes Críticos y Escenarios de Fallo: El DRP contempla los siguientes componentes críticos del sistema y sus escenarios de fallo más probables, derivados de la Matriz de Riesgos del Capítulo III:

Componente	Escenario de fallo	Riesgo asociado	Impacto
------------	--------------------	-----------------	---------

Servidor VPS	Caída del proveedor, fallo técnico o borrado accidental	R10 (Crítico = 20)	Sistema completamente inaccesible
Base de datos PostgreSQL	Corrupción de datos, ataque de ransomware	R09 (Medio = 10)	Pérdida parcial o total de datos
PC del organizador	Fallo de hardware, infección por virus	R11 (Medio = 12)	Imposibilidad de acceso al panel administrativo desde la sede
Conexión a internet (Estadio Patria)	Caída del ISP durante registro en vivo	R14 (Medio = 12)	Organizador sin acceso al sistema desde la oficina
Repositorio GitHub	Pérdida o corrupción del código fuente	-	Imposibilidad de redesplicue del sistema

5.2.4. Procedimientos de Recuperación por Escenario

Escenario A — Caída del Servidor VPS

Este es el escenario de mayor criticidad (R10, nivel 20) y el que activa el DRP completo.

Fase 1 — Detección (0 a 30 minutos):

- El organizador o cualquier usuario detecta que el sistema no responde y notifica al Responsable del SGSI por llamada directa.
- El Responsable del SGSI verifica el estado del VPS desde el panel de control del proveedor.
- Se confirma si la caída es del proveedor (fallo externo) o del sistema desplegado (fallo interno).

Fase 2 — Respuesta inmediata (30 minutos a 2 horas):

- Si es fallo del proveedor: monitorear el canal de estado oficial del proveedor VPS y esperar restauración. Activar comunicación a usuarios (punto 5.2.5).
- Si es fallo interno: acceder al VPS por SSH, revisar logs del sistema (journalctl, logs de Nginx y NestJS) para identificar la causa raíz.
- Reiniciar los servicios afectados en el siguiente orden: primero PostgreSQL, luego NestJS, finalmente Nginx.

Fase 3 — Restauración desde respaldo (2 a 4 horas, si hay pérdida de datos):

- Acceder al almacenamiento externo donde se encuentran los dumps cifrados de PostgreSQL.

- Seleccionar el respaldo más reciente disponible (máximo 24 horas de antigüedad conforme al RPO).
- Restaurar la base de datos:

Descifrar el respaldo

```
gpg --decrypt backup_ampfs_YYYYMMDD.sql.gpg >
backup_ampfs.sql
```

Restaurar en PostgreSQL

```
psql -U postgres -d ampfs-udc-db -f backup_ampfs.sql
```

- Verificar integridad de los datos restaurados comparando con las planillas físicas del último día de partidos.
- Reiniciar servicios y confirmar operatividad del sistema.

Fase 4 — Cierre del incidente:

- El Responsable del SGSI documenta el incidente: causa, duración, datos afectados y acciones tomadas.
- Si hubo pérdida de datos reconstruibles desde planillas físicas, el organizador ingresa manualmente los registros faltantes.
- Se genera un informe de no conformidad para análisis de causa raíz y mejora del control fallido.

Escenario B — Caída de Internet en el Estadio Patria Durante un Día de Partidos

Este escenario no implica pérdida de datos ni caída del VPS, sino imposibilidad temporal del organizador de acceder al sistema desde la sede.

Procedimiento:

- El organizador continúa la jornada deportiva normalmente apoyándose en las planillas físicas impresas previamente, que contienen los fixtures del día.
- Los árbitros registran resultados en las planillas físicas como de costumbre.
- El organizador ingresa los resultados al sistema una vez restaurada la conectividad, que puede ser desde la sede o desde cualquier dispositivo con acceso a internet (dispositivo móvil con datos).

- No se activa ningún procedimiento de emergencia adicional dado que la operación deportiva no depende del sistema en tiempo real.

Escenario C — Fallo de la PC del Organizador

Procedimiento:

- El organizador accede al sistema desde cualquier otro dispositivo con navegador web (dispositivo móvil propio u otro equipo disponible), dado que el sistema es una aplicación web y no depende de software instalado localmente.
- Se reporta el fallo de hardware al Responsable del SGSI para gestionar la reparación o reemplazo del equipo.
- Los Kardex físicos y planillas custodiadas en la oficina administrativa no se ven afectados por el fallo del equipo.

Escenario D — Pérdida o Compromiso del Repositorio GitHub

Procedimiento:

- Cada miembro del equipo de desarrollo mantiene una copia local del repositorio en su equipo de trabajo (clon local de Git), lo que garantiza que el código fuente nunca exista en un único punto de falla.
- En caso de compromiso de la cuenta de GitHub, el equipo de desarrollo revoca los accesos comprometidos, cambia las credenciales y restaura el repositorio desde cualquier clon local disponible.

Se activa la revisión de seguridad de las ramas protegidas (main, dev, SGSI) para verificar que no se hayan introducido cambios maliciosos.

5.2.5. Plan de comunicación Durante un Incidente: Durante la activación del DRP, la comunicación con los usuarios del

sistema sigue el siguiente protocolo, utilizando los canales institucionales ya definidos en el punto 5.1.3:

Tiempo desde el incidente	Acción de comunicación	Canal	Responsable
0 a 30 minutos	Confirmación interna del incidente	Llamada directa	Responsable del SGSI
30 minutos a 1 hora	Notificación a la directiva y al organizador	WhatsApp institucional	Responsable del SGSI
1 hora	Comunicación a delegados y jugadores si el incidente ocurre en día de partidos	WhatsApp grupal de la Asociación	Organizador
Cada 2 horas	Actualización del estado de recuperación	WhatsApp institucional	Responsable del SGSI
Al restaurar el servicio	Confirmación de operatividad y resumen del incidente	WhatsApp institucional + reunión presencial posterior	Responsable del SGSI

Mensaje tipo para comunicación a usuarios durante un incidente:

"El sistema de gestión de campeonatos de la AMPFS se encuentra temporalmente fuera de servicio. Los partidos programados continúan con normalidad. Los resultados serán registrados en el sistema una vez restaurado el servicio. Pedimos disculpas por los inconvenientes."

- 5.2.6. Política de Respaldos como Base del DRP:** El DRP descansa sobre la política de respaldos automatizados definida en el punto 4.5.6, cuya correcta implementación es condición indispensable para que los tiempos RTO y RPO definidos sean alcanzables. Se reitera que mientras esta política no esté implementada en el VPS de producción, el sistema opera sin capacidad de recuperación ante el escenario A, manteniendo el riesgo R10 en nivel Crítico. La siguiente tabla resume el estado de preparación del DRP en función de los controles pendientes:

Control	Estado	Impacto en el DRP si no se implementa
Cron Job de respaldo diario (pg_dump)	Pendiente	Sin RPO garantizado — pérdida total de datos posible

Almacenamiento externo cifrado	Pendiente	Sin punto de restauración disponible para el Escenario A
Nginx como reverse proxy	Pendiente	Sin HTTPS ni aislamiento de puertos en producción
Audit Log inmutable	Pendiente crítico	Sin trazabilidad para verificar integridad post-restauración
Política de privacidad en el frontend	Pendiente crítico	Incumplimiento de Ley N° 164 desde el primer registro de jugador

5.3. Métricas e Indicadores (KPIs): Las métricas e indicadores de desempeño (KPIs, Key Performance Indicators) constituyen el mecanismo formal mediante el cual la Asociación Municipal de Pelota Frontón Sucre evalúa la efectividad de su SGSI, en cumplimiento de la cláusula 9.1 de la norma ISO/IEC 27001:2022 y los principios de medición definidos en la ISO/IEC 27004 (Monitoreo, medición, análisis y evaluación). Sin métricas definidas, la mejora continua del ciclo PHVA establecida en la PSI no puede verificarse objetivamente.

5.3.1. Responsabilidad y Ciclo de Medición: El Responsable del SGSI / CISO es el encargado de recopilar, calcular y reportar todos los KPIs definidos en el presente apartado. Los resultados se presentan ante la directiva de la Asociación en las reuniones semanales de los días miércoles durante los periodos de campeonato activo, y con frecuencia mensual fuera de temporada.

El ciclo de medición sigue la siguiente estructura:

Periodo	Actividad de medición	Canal de reporte
Semanal (miércoles, campeonato activo)	Revisión operativa de KPIs técnicos y de incidentes	Reunión presencial de directiva
Mensual (fuera de temporada)	Revisión general del estado del SGSI	Reunión presencial reducida
Anual	Evaluación completa del desempeño del SGSI — insumo para la revisión por la dirección (Cap. VI)	Reunión formal con toda la directiva

5.3.2. Línea Base de Medición: Antes de la implementación del presente SGSI, la Asociación operaba sin controles formales de seguridad de la información. Durante ese periodo se registraron incidentes relacionados con la filtración de fixtures ("teje") y disputas por resultados, con una frecuencia que ha disminuido progresivamente pero sin llegar a cero debido a la ausencia de controles técnicos. Esta situación constituye la línea base sobre la cual se medirá el impacto real del SGSI una vez implementado.

El objetivo general de las métricas es demostrar, con datos objetivos, que la implementación del SGSI reduce la frecuencia e impacto de los incidentes de seguridad respecto a esta línea base histórica.

5.3.3. Cuadro de KPIs del SGSI: Los indicadores se organizan en cuatro categorías alineadas a los dominios de control definidos a lo largo del documento:

Categoría 1 — Seguridad de la Aplicación

KPI	Descripción	Fórmula	Meta	Frecuencia
KPI-01	Cobertura de validación de entradas	$(\text{Endpoints con ValidationPipe} / \text{Total de endpoints}) \times 100$	100%	Por sprint
KPI-02	Vulnerabilidades detectadas por pnpm audit sin resolver	Número de CVEs high o critical sin parche aplicado en producción	0	Por sprint
KPI-03	Pull Requests mergeados sin revisión de seguridad	Número de PRs fusionados a ramas protegidas sin aprobación del revisor designado	0	Semanal
KPI-04	Cobertura del Audit Log sobre operaciones críticas	$(\text{Operaciones sensibles registradas en el log} / \text{Total de operaciones sensibles ejecutadas}) \times 100$	100%	Mensual

Categoría 2 — Gestión de Incidentes

KPI	Descripción	Fórmula	Meta	Frecuencia
KPI-05	Incidentes de filtración de fixtures ("teje")	Número de incidentes confirmados de filtración de cronogramas antes de su publicación oficial	0	Por campeonato
KPI-06	Incidentes de alteración de resultados	Número de reclamaciones fundadas por modificación no autorizada de marcadores registrados	0	Por campeonato
KPI-07	Tiempo medio de respuesta ante incidentes (MTTR)	$\text{Suma de tiempos de resolución de incidentes} / \text{Número}$	≤ 4 horas	Por incidente

		de incidentes resueltos		
KPI-08	Incidentes resueltos dentro del RTO definido	$(\text{Incidentes resueltos en } \leq 24 \text{ horas} / \text{Total de incidentes}) \times 100$	$\geq 95\%$	Mensual

Categoría 3 — Continuidad y Disponibilidad

KPI	Descripción	Fórmula	Meta	Frecuencia
KPI-09	Disponibilidad del sistema en días de campeonato	$(\text{Horas disponibles en fines de semana de campeonato} / \text{Total de horas de fin de semana}) \times 100$	$\geq 99\%$	Por campeonato
KPI-10	Ejecución exitosa de respaldos automáticos	$(\text{Respaldos ejecutados correctamente} / \text{Total de respaldos programados}) \times 100$	100%	Semanal
KPI-11	Antigüedad máxima del respaldo disponible	Tiempo transcurrido desde el último respaldo verificado exitosamente	≤ 24	Diario
KPI-12	Restauraciones de prueba realizadas	Número de restauraciones de prueba ejecutadas para verificar integridad de los respaldos	1 por mes	Mensual

Categoría 4 — Concienciación y Cumplimiento

KPI	Descripción	Fórmula	Meta	Frecuencia
KPI-13	Cobertura del programa de concienciación	$(\text{Miembros de la directiva capacitados} / \text{Total de miembros de la directiva}) \times 100$	100% antes del despliegue	Por sesión
KPI-14	Jugadores con política de privacidad aceptada	$(\text{Jugadores que aceptaron la política de privacidad} / \text{Total de jugadores registrados}) \times 100$	100%	Mensual
KPI-15	Incidentes por incumplimiento de la PSI	Número de infracciones documentadas a las políticas definidas en la PSI (ej. envío de fixtures por WhatsApp)	0	Mensual
KPI-16	Controles pendientes críticos implementados	Número de controles marcados como	3 de 3 antes del	Por sprint

		pendientes críticos (Audit Log, política de privacidad, respaldos) que han sido implementados	despliegue	
--	--	---	------------	--

5.3.4. Dashboard de Seguimiento del SGSI: Para facilitar la revisión semanal durante las reuniones de directiva, el Responsable del SGSI mantendrá un registro de seguimiento simplificado — que puede implementarse inicialmente en una hoja de cálculo compartida — con el estado actual de cada KPI, usando el siguiente esquema de semáforo:

Estado	Indicador	Criterio
Cumplido	El KPI alcanza o supera su meta definida	Sin acción requerida
En riesgo	El KPI se encuentra entre el 80% y el 99% de su meta	Monitoreo reforzado y plan de acción en 7 días
Incumplido	El KPI está por debajo del 80% de su meta o registra un incidente crítico	Acción correctiva inmediata — activa el procedimiento de no conformidad de la PSI

5.3.5. Conexión entre KPIs y Mejora Continua: Los resultados acumulados de los KPIs son el insumo principal para los dos procesos del Capítulo VI: la Auditoría Interna y la Revisión por la Dirección. La siguiente tabla muestra qué KPIs alimentan directamente cada proceso de mejora:

KPI	Proceso de mejora que alimenta
KPI-01, KPI-02, KPI-03, KPI-04	Auditoría técnica del equipo de desarrollo — Cap. VI.1
KPI-05, KPI-06, KPI-07, KPI-08	Revisión de gestión de incidentes — Cap. VI.1 y VI.2
KPI-09, KPI-10, KPI-11, KPI-12	Revisión del DRP y política de respaldos — Cap. VI.2
KPI-13, KPI-14, KPI-15, KPI-16	Revisión del programa de concienciación y cumplimiento — Cap. VI.2

VII. CAPITULO VI: EVALUACIÓN Y MEJORA

6.1. Auditoría Interna: La auditoría interna constituye el mecanismo formal mediante el cual la Asociación Municipal de Pelota Frontón Sucre verifica que su SGSI cumple con los requisitos de la norma ISO/IEC 27001:2022, los controles definidos en la Declaración de Aplicabilidad (SoA) del Capítulo III y las políticas establecidas en la PSI. Su realización está regulada por la cláusula 9.2 de la norma, que exige

que el proceso sea planificado, objetivo e independiente del equipo responsable del diseño e implementación del sistema.

6.1.1. Independencia del Proceso de Auditoría: En cumplimiento estricto de la cláusula 9.2.2 de la ISO/IEC 27001:2022, que establece que los auditores no deben auditar su propio trabajo, la Asociación Municipal de Pelota Frontón Sucre define la siguiente separación de responsabilidades para el proceso de auditoría:

Equipo	Rol del SGSI	Rol de la Auditoría
Equipo SGSI (Mendez, Loayza Axel, Polo, Vela, Rodas, Leaños, Manjon, Vargas, Wilder, Sucullani)	Diseño, implementación y operación del SGSI	Auditado — no participa en la evaluación
Equipo Auditor Designado	Independiente del equipo SGSI	Auditor Interno — evalúa la conformidad del SGSI
Agustín Oscar Loayza Torrez	-	Responsable del Equipo Auditor — lidera y coordina el proceso de auditoría interna

Esta estructura garantiza la objetividad e imparcialidad del proceso, dado que el equipo auditor no estuvo involucrado en el diseño ni en la implementación de los controles que evaluará.

6.1.2. Planificación de la Auditoría Interna: La auditoría interna está planificada para realizarse antes del despliegue del sistema en producción, constituyendo una compuerta de calidad y seguridad que el SGSI debe superar antes de operar con datos reales de los atletas de la Asociación.

Elemento	Detalle
Momento de ejecución	Previo al despliegue en producción del sistema
Responsable	Agustín Oscar Loayza Torrez (Responsable del Equipo Auditor Designado)
Alcance	Todos los controles definidos en la SoA del Capítulo III y los ASC del Capítulo IV
Criterios de auditoría	ISO/IEC 27001:2022, ISO/IEC 27034, PSI de la Asociación y controles del Anexo A de la ISO 27002:2022
Método	Revisión documental, entrevistas al equipo SGSI y verificación técnica de los controles implementados

6.1.3. Alcance y Áreas de Evaluación: El equipo auditor evaluará las siguientes áreas, derivadas de los capítulos del presente SGSI:

Área 1 — Documentación y Política

- ¿La Política de Seguridad de la Información (PSI) está formalmente aprobada por la Alta Dirección?
- ¿Los roles y responsabilidades definidos en el Capítulo II están asignados a personas reales y comunicados formalmente?
- ¿La Declaración de Aplicabilidad (SoA) refleja con precisión los controles implementados y excluidos?

Área 2 — Gestión de Riesgos

- ¿La Matriz de Riesgos del Capítulo III fue elaborada siguiendo la metodología ISO/IEC 27005 definida?
- ¿El Plan de Tratamiento de Riesgos tiene responsables asignados y fechas de implementación?
- ¿Los 6 riesgos críticos identificados tienen controles técnicos verificables en el sistema?

Área 3 — Controles Técnicos de Seguridad (ASC)

- ¿Helmet está correctamente configurado y activo en el backend NestJS?
- ¿El ValidationPipe global está implementado y rechaza entradas malformadas?
- ¿Los Guards JWT protegen todos los endpoints que manejan PII o datos de fixtures?
- ¿TypeORM es el único mecanismo de acceso a la base de datos (sin raw queries)?
- ¿El Audit Log inmutable está implementado antes del despliegue? (Control crítico pendiente)
- ¿La política de privacidad está integrada en el frontend como paso obligatorio del registro? (Control crítico pendiente)

Área 4 — Seguridad de Red e Infraestructura

- ¿Nginx está configurado como reverse proxy con redirección forzada HTTP → HTTPS?
- ¿El certificado SSL está activo y vigente?
- ¿El hardening SSH del VPS está aplicado (puerto no estándar, sin autenticación por contraseña, sin login root)?

- ¿Los Cron Jobs de respaldo automático están activos y verificados?

Área 5 — Concienciación y Continuidad

- ¿La sesión de concienciación para la directiva fue realizada y documentada?
- ¿El DRP fue comunicado al Responsable del SGSI y al organizador?
- ¿Los KPIs definidos en el punto 5.3 tienen un mecanismo de seguimiento activo?

6.1.4. Criterios de Conformidad: Los hallazgos de la auditoría se clasificarán según los siguientes criterios estándar de la ISO 19011 (Directrices para la auditoría de sistemas de gestión):

Clasificación	Definición	Acción requerida
Conforme (C)	El control está implementado y cumple el requisito de la norma	Ninguna — mantener y monitorear
No Conformidad Mayor (NCM)	El control está ausente o falla de forma que compromete la efectividad del SGSI	Acción correctiva obligatoria antes del despliegue
No Conformidad Menor (NCm)	El control está implementado pero con desviaciones menores que no comprometen el SGSI	Plan de acción correctiva en plazo acordado
Observación (OBS)	Oportunidad de mejora identificada sin incumplimiento formal	Evaluación y mejora voluntaria

Conforme al estado actual del SGSI, los controles críticos pendientes — Audit Log inmutable (ASC-08), política de privacidad en el frontend y respaldos automatizados — serán evaluados por el equipo auditor como No Conformidades Mayores si no están implementados al momento de la auditoría, bloqueando el despliegue en producción hasta su resolución.

6.1.5. Informe de Auditoría: Al concluir el proceso, el Responsable del Equipo Auditor (Agustín Oscar Loayza Torrez) emitirá un Informe de Auditoría Interna que contendrá como mínimo:

- Alcance y criterios de la auditoría.
- Metodología y técnicas utilizadas.
- Listado de hallazgos clasificados por criterio (C, NCM, NCm, OBS).
- Evidencias recopiladas para cada hallazgo.
- Conclusión general sobre la conformidad del SGSI.

- Recomendaciones de mejora.

Este informe será entregado formalmente al Responsable del SGSI y al Presidente de la Asociación para su revisión y aprobación, activando el proceso de Revisión por la Dirección definido en el punto siguiente.

6.2. Revisión por la Dirección: La Revisión por la Dirección es el proceso formal mediante el cual la Alta Dirección de la Asociación evalúa el desempeño global del SGSI y toma decisiones estratégicas para su mejora continua, en cumplimiento de la cláusula 9.3 de la ISO/IEC 27001:2022. Para la AMPFS, este proceso recae principalmente sobre el Organizador como actor técnico activo y el Presidente como autoridad máxima de aprobación final.

6.2.1. Entradas de la Revisión: La revisión por la dirección se nutre de las siguientes fuentes de información, todas generadas por los procesos definidos en capítulos anteriores:

Entrada	Fuente
Resultados de los KPIs del periodo (Cap. 5.3)	Responsable del SGSI
Informe de Auditoría Interna (Cap. 6.1)	Agustín Oscar Loayza Torrez
Estado de los controles pendientes críticos	Equipo de Desarrollo
Incidentes de seguridad registrados en el periodo	Responsable del SGSI
Estado del DRP y resultados de restauraciones de prueba (Cap. 5.2)	Administrador del Sistema
Cambios en el contexto institucional o en las amenazas identificadas	Alta Dirección
Retroalimentación de jugadores, delegados y clubes afiliados	Organizador

6.2.2. Proceso de Revisión: La revisión se realiza en sesión formal con la participación del Presidente, el Responsable del SGSI y el Organizador, siguiendo el calendario definido en el punto 5.3.1:

- **Durante campeonato activo:** Revisión operativa semanal los miércoles, enfocada en KPIs de incidentes y disponibilidad.
- **Revisión anual completa:** Sesión formal con toda la directiva, evaluando el desempeño global del SGSI y tomando decisiones de mejora para el siguiente periodo.

El Responsable del SGSI presenta los resultados. El Organizador aporta contexto operativo sobre el comportamiento del sistema. El Presidente toma las

decisiones finales sobre recursos, prioridades y aprobación de cambios al SGSI.

6.2.3. Salidas de la Revisión: Como resultado de cada revisión formal, la dirección debe producir decisiones documentadas sobre:

- Aprobación o rechazo de acciones correctivas propuestas ante no conformidades.
- Asignación de recursos para implementar controles pendientes.
- Actualización de la Política de Seguridad de la Información si el contexto institucional ha cambiado.
- Modificaciones al alcance del SGSI ante nuevas funcionalidades del sistema o cambios en la estructura de la Asociación.
- Objetivos de seguridad para el siguiente periodo de campeonato.

Todas las decisiones tomadas en la revisión por la dirección quedan registradas en el acta de reunión correspondiente, firmada por el Presidente como evidencia de su compromiso con el SGSI conforme a la cláusula 5.1 de la norma.

6.3. Mejora Continua (Ciclo PHVA): La mejora continua es el principio que garantiza que el SGSI de la Asociación evolucione ante nuevas amenazas, cambios tecnológicos y lecciones aprendidas de los incidentes registrados, en cumplimiento de la cláusula 10 de la ISO/IEC 27001:2022. Se implementa mediante el ciclo PHVA (Planificar — Hacer — Verificar — Actuar), aplicado de forma iterativa sobre todos los procesos del SGSI.

6.3.1. Aplicación del Ciclo PHVA al SGSI de la AMPFS

Fase	Descripción	Aplicación concreta en la AMPFS
Planificar	Identificar riesgos, definir controles y establecer objetivos de seguridad	Elaboración de la Matriz de Riesgos (Cap. III), definición de ASC (Cap. IV) y KPIs (Cap. V)
Hacer	Implementar los controles y procedimientos planificados	Desarrollo del software con controles de seguridad integrados, capacitación de la directiva, configuración del VPS
Verificar	Medir el desempeño mediante KPIs y auditorías	Seguimiento semanal de KPIs en reuniones de los miércoles, auditoría interna previa al despliegue

Actuar	Tomar decisiones de mejora basadas en los resultados de la verificación	Revisión por la dirección, acciones correctivas ante no conformidades, actualización de controles
--------	---	---

6.3.2. **Gestión de No Conformidades y Acciones Correctivas:**

Cuando un KPI entra en estado o la auditoría interna identifica una No Conformidad, se activa el siguiente procedimiento de acción correctiva, alineado a la cláusula 10.1 de la norma:

- **Paso 1 — Registro:** El Responsable del SGSI documenta la no conformidad indicando: descripción del hallazgo, control afectado, fecha de detección y clasificación (NCM o NCm).
- **Paso 2 — Análisis de causa raíz:** Se identifica la causa que originó la no conformidad, diferenciando entre fallo técnico, fallo humano o ausencia de control. Para la AMPFS, las herramientas de análisis recomendadas son los 5 Porqués o el Diagrama de Ishikawa, por su simplicidad y aplicabilidad sin herramientas especializadas.
- **Paso 3 — Acción correctiva:** Se define e implementa la medida que elimina la causa raíz, no solo el síntoma. Por ejemplo, si un endpoint no tiene Guard JWT (síntoma), la acción correctiva no es solo agregar el Guard, sino revisar todos los endpoints del sistema para garantizar cobertura total (causa raíz: ausencia de checklist de seguridad en el proceso de PR).
- **Paso 4 — Verificación de eficacia:** El Responsable del SGSI verifica que la acción correctiva resolvió efectivamente la no conformidad antes de cerrarla, revisando el KPI correspondiente en el siguiente ciclo de medición.
- **Paso 5 — Cierre y lección aprendida:** La no conformidad se cierra formalmente y la lección aprendida se incorpora como mejora al proceso afectado, actualizando la documentación del SGSI si corresponde.

6.3.3. **Hoja de Ruta de Mejora Inmediata:** Como resultado del diseño del presente SGSI, se identifican las siguientes acciones de mejora de carácter inmediato, ordenadas por prioridad antes del despliegue en producción:

Prioridad	Acción	Responsable	Condición
1	Implementar Audit Log inmutable en PostgreSQL (ASC-08)	Equipo de Desarrollo	Bloqueante para US-33 y US-34
2	Integrar política de privacidad en el frontend como paso obligatorio del registro	Equipo de Desarrollo	Bloqueante para despliegue en producción
3	Configurar Cron Job de respaldo diario con almacenamiento externo cifrado	Administrador del Sistema	Bloqueante para despliegue en producción
4	Definir FRONTEND_API_URL en el .env de producción del VPS	Equipo de Desarrollo	Requerido antes del despliegue
5	Deshabilitar Swagger UI en entorno de producción	Equipo de Desarrollo	Requerido antes del despliegue
6	Configurar Nginx con redirección HTTP → HTTPS y certificado Let's Encrypt	Administrador del Sistema	Requerido antes del despliegue
7	Aplicar hardening SSH en el VPS (puerto, claves, sin root)	Administrador del Sistema	Requerido antes del despliegue
8	Realizar sesión de concienciación formal para la directiva	Responsable del SGSI	Requerido antes del despliegue
9	Seleccionar proveedor VPS con certificación ISO/IEC 27018	Equipo de Seguridad y Cumplimiento	Requerido antes del despliegue
10	Configurar IP estática para la PC del organizador y hardening del router	Organizador / Administrador	Mejora recomendada post-despliegue

VIII. CONCLUSIONES Y RECOMENDACIONES

i. Conclusiones

- Se diseñó un Sistema de Gestión de Seguridad de la Información (SGSI) para la Asociación Municipal de Pelota Frontón Sucre, alineado con los requisitos de la norma ISO/IEC 27001:2022, permitiendo establecer políticas, procedimientos y controles destinados a proteger los activos de información de la institución.
- La aplicación de la metodología de gestión de riesgos basada en la norma ISO/IEC 27005 permitió identificar dieciséis riesgos asociados a los activos tecnológicos, documentales y administrativos de la Asociación, determinando que seis de ellos presentan un nivel crítico y requieren tratamiento prioritario.
- El análisis realizado evidenció que los principales riesgos se encuentran relacionados con la integridad de los resultados deportivos, la protección de los datos personales de los atletas, la

disponibilidad de la información almacenada en el servidor y la gestión de los registros financieros institucionales.

- La incorporación de controles técnicos fundamentados en la norma ISO/IEC 27034 fortalece el desarrollo seguro del sistema informático mediante mecanismos de autenticación, control de acceso, validación de datos, auditoría de operaciones y protección frente a vulnerabilidades comunes en aplicaciones web.
- La implementación de las medidas propuestas contribuirá significativamente a reducir la probabilidad e impacto de incidentes de seguridad, fortaleciendo la confianza en los procesos deportivos y administrativos de la Asociación.
- El SGSI propuesto constituye una base sólida para impulsar la transformación digital de la Asociación Municipal de Pelota Frontón Sucre, promoviendo la mejora continua, la gestión responsable de la información y el cumplimiento de buenas prácticas internacionales en seguridad de la información.

ii. Recomendaciones

- Implementar progresivamente los controles definidos en el Plan de Tratamiento de Riesgos, priorizando aquellos asociados a los riesgos clasificados como críticos.
- Establecer una política formal de copias de seguridad automáticas y pruebas periódicas de restauración para garantizar la recuperación de la información ante incidentes o fallos técnicos.
- Implementar el módulo de auditoría (Audit Log) antes de la puesta en producción del sistema, con el fin de garantizar la trazabilidad de las operaciones sensibles realizadas por los usuarios.
- Capacitar periódicamente a los miembros de la directiva, organizadores y usuarios del sistema sobre buenas prácticas de seguridad de la información y protección de datos personales.
- Realizar revisiones y evaluaciones de riesgos al menos una vez por año o cuando se produzcan cambios significativos en la infraestructura tecnológica o en los procesos de la Asociación.
- Considerar en futuras etapas la implementación de mecanismos adicionales de seguridad, como autenticación multifactor (MFA), monitoreo continuo de eventos de seguridad y pruebas periódicas de vulnerabilidades.

IX. BIBLIOGRAFÍA

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.

International Organization for Standardization. (2022). *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls*. ISO.

International Organization for Standardization. (2022). *ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection — Guidance on managing information security risks*. ISO.

International Organization for Standardization. (2019). *ISO/IEC 27018:2019 Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors*. ISO.

International Organization for Standardization. (2011). *ISO/IEC 27031:2011 Guidelines for information and communication technology readiness for business continuity*. ISO.

International Organization for Standardization. (2024). *ISO/IEC 27034-1 Application Security — Part 1: Overview and concepts*. ISO.

Stallings, W. (2018). *Effective Cybersecurity: A Guide to Using Best Practices and Standards*. Pearson Education.

Whitman, M. E., & Mattord, H. J. (2021). *Principles of Information Security* (7th ed.). Cengage Learning.

Peltier, T. R. (2016). *Information Security Policies, Procedures, and Standards: Guidelines for Effective Information Security Management*. Auerbach Publications.

Calder, A. (2023). *ISO 27001:2022 – A Pocket Guide*. IT Governance Publishing.

Calder, A., & Watkins, S. (2021). *IT Governance: An International Guide to Data Security and ISO 27001/ISO 27002* (7th ed.). Kogan Page.

Von Solms, B., & Van Niekerk, J. (2013). *Information Security Governance*. Springer.

Siponen, M., Mahmood, M. A., & Pahlila, S. (2014). Employees' adherence to information security policies: An exploratory field study. *Information & Management*, 51(2), 217–224.

AlHogail, A. (2015). Design and validation of information security culture framework. *Computers in Human Behavior*, 49, 567–575.

Baskerville, R., & Siponen, M. (2002). An information security meta-policy for emergent organizations. *Logistics Information Management*, 15(5/6), 337–346.

Estado Plurinacional de Bolivia. (2011). *Ley N.º 164. Ley General de Telecomunicaciones, Tecnologías de Información y Comunicación*. Gaceta Oficial del Estado Plurinacional de Bolivia.

NestJS.(2025).*Authentication*. <https://docs.nestjs.com/security/authentication>

NestJS. (2025). *Authorization*. <https://docs.nestjs.com/security/authorization>

TypeORM. (2025). *TypeORM Documentation*. <https://typeorm.io>

PostgreSQL Global Development Group. (2025). *PostgreSQL Documentation*. <https://www.postgresql.org/docs/>

GitHub Inc. (2025). *GitHub Docs*. <https://docs.github.com>

OWASP Foundation. (2025). *OWASP Top 10 Web Application Security Risks*. <https://owasp.org/www-project-top-ten/>

National Institute of Standards and Technology (NIST). (2025). *Cybersecurity Framework (CSF) 2.0*. <https://www.nist.gov/cyberframework>

Center for Internet Security (CIS). (2025). *CIS Controls Version 8*. <https://www.cisecurity.org/controls>

IT Governance Ltd. (2025). *ISO 27001 Resource Center*. <https://www.itgovernance.co.uk/iso27001>

ENISA. (2024). *Threat Landscape Report*. Recuperado de <https://www.enisa.europa.eu>

Cloud Security Alliance. (2024). *Security Guidance for Critical Areas of Cloud Computing*. Recuperado de <https://cloudsecurityalliance.org>

Amazon Web Services. (2024). *AWS Security Best Practices*. Recuperado de <https://docs.aws.amazon.com>